Center for Internet Security®

CIS Palo Alto Firewall 6 Benchmark

v1.0.0 - 09-30-2016

ARCHIVE

This work is licensed under a Creative Commons Attribution-NonCommercial-ShareAlike 4.0 International Public License. The link to the license terms can be found at https://creativecommons.org/licenses/by-nc-sa/4.0/legalcode

To further clarify the Creative Commons license related to CIS Benchmark content, you are authorized to copy and redistribute the content for use by you, within your organization and outside your organization for non-commercial purposes only, provided that (i) appropriate credit is given to CIS, (ii) a link to the license is provided. Additionally, if you remix, transform or build upon the CIS Benchmark(s), you may only distribute the modified materials if they are subject to the same license terms as the original Benchmark license and your derivative will no longer be a CIS Benchmark. Commercial use of CIS Benchmarks is subject to the prior approval of the Center for Internet Security.

ARCHIVE

Table of Contents

Overview 7
Intended Audience 7
Consensus Guidance 7
Typographical Conventions 8
Scoring Information 8
Profile Definitions 9
Acknowledgements 10
Recommendations 11
1 Device Setup 11
1.1 General Settings 12
1.1.1 Ensure 'Login Banner' is set (Scored) 12
1.1.2 Ensure 'Enable Log on High DP Load' is enabled (Scored) 14
1.2 Management Interface Settings 16
1.2.1 Ensure 'Permitted IP Addresses' is set to those necessary for device management (Scored) 16
1.2.2 Ensure 'Permitted IP Addresses' is set for all management profiles where SSH, HTTPS, or SNMP is enabled (Scored) 18
1.2.3 Ensure HTTP and Telnet options are disabled for the Management Interface (Scored) 19
1.2.4 Ensure valid certificate is set for browser-based administrator interface (Not Scored) 20
1.3 Minimum Password Requirements 22
1.3.1 Ensure 'Minimum Password Complexity' is enabled (Scored) 22
1.3.2 Ensure 'Minimum Length' is greater than or equal to 12 (Scored) 24
1.3.3 Ensure 'Prevent Password Reuse Limit' is set to 24 or more passwords (Scored) 26
1.3.4 Ensure 'Required Password Change Period' is less than or equal to 90 days (Scored) 28

ARCHIVE

1.3.5 Ensure 'Password Profiles' do not exist (Scored) 30
1.3.6 Ensure 'Minimum Uppercase Letters' is greater than or equal to 1 (Scored) .. 32
1.3.7 Ensure 'Minimum Lowercase Letters' is greater than or equal to 1 (Scored) .. 34
1.3.8 Ensure 'Minimum Numeric Letters' is greater than or equal to 1 (Scored) 36
1.3.9 Ensure 'Minimum Special Characters' is greater than or equal to 1 (Scored) .. 38
1.3.10 Ensure 'Block Username Inclusion' is enabled (Scored) 40
1.3.11 Ensure 'New Password Differs by Characters' is greater than or equal to 3 (Scored) 42
1.4 Authentication Settings (for Device Mgmt) 44
1.4.1 Ensure 'Idle timeout' is less than or equal to 10 minutes for device management (Scored) 44
1.4.2 Ensure 'Failed Attempts' and 'Lockout Time' for Authentication Profile are properly configured (Scored) 46
1.5 SNMP Polling Settings 48
1.5.1 Ensure 'V3' is selected for SNMP polling (Scored) 48
1.6 Device Services Settings 50
1.6.1 Ensure 'Verify Update Server Identity' is enabled (Scored) 50
1.6.2 Ensure redundant NTP servers are configured appropriately (Scored) 52
1.6.3 Ensure that the certificate securing Remote Access VPNs is valid (Not Scored) 54
2 User Identification 56
2.1 Ensure that IP addresses are mapped to usernames (Scored) 56
2.2 Ensure that WMI probing is disabled (Scored) 58
2.3 Ensure that User-ID is only enabled for internal trusted interfaces (Scored) 60
2.4 Ensure that 'Include/Exclude Networks' is used if User-ID is enabled (Scored) 61
2.5 Ensure that the User-ID Agent has minimal permissions if User-ID is enabled (Scored) 63
2.6 Ensure that the User-ID service account does not have interactive logon rights (Scored) 65
2.7 Ensure remote access capabilities for the User-ID service account are forbidden. (Not Scored) 67

ARCHIVE

2.8 Ensure that security policies restrict User-ID Agent traffic from crossing into untrusted zones (Scored) 69
3 High Availability 71
3.1 Ensure a fully-synchronized High Availability peer is configured (Scored) 71
3.2 Ensure 'High Availability' requires Link Monitoring and/or Path Monitoring (Scored) 73
3.3 Ensure 'Passive Link State' and 'Preemptive' are configured appropriately (Scored) 75
4 Dynamic Updates 77
4.1 Ensure 'Antivirus Update Schedule' is set to download and install updates hourly (Scored) 77
4.2 Ensure 'Applications and Threats Update Schedule' is set to download and install updates daily (Scored) 79
5 Wildfire 81
5.1 Ensure that WildFire file size upload limits are maximized (Scored) 81
5.2 Ensure forwarding is enabled for all applications and file types in WildFire file blocking profiles (Scored) 83
5.3 Ensure a WildFire file blocking profile is enabled for all security policies allowing Internet traffic flows (Scored) 85
5.4 Ensure forwarding of decrypted content to WildFire is enabled (Scored) 87
5.5 Ensure all WildFire session information settings are enabled (Scored) 89
5.6 Ensure alerts are enabled for malicious files detected by WildFire (Scored) 90
5.7 Ensure 'WildFire Update Schedule' is set to download and install updates every 15 minutes (Scored) 92
6 Security Profiles 94
6.1 Ensure at least one antivirus profile is set to block on all decoders except 'imap' and 'pop3' (Scored) 94
6.2 Ensure a secure antivirus profile is applied to all relevant security policies (Scored) 96
6.3 Ensure an anti-spyware profile is configured to block on all spyware severity levels, categories, and threats (Scored) 98
6.4 Ensure DNS sinkholing is configured on all anti-spyware profiles in use (Scored) 99

ARCHIVE

6.5 Ensure passive DNS monitoring is set to enabled on all anti-spyware profiles in use (Scored) 101

6.6 Ensure a secure anti-spyware profile is applied to all security policies permitting traffic to the Internet (Scored) 102

6.7 Ensure a Vulnerability Protection Profile is set to block attacks against critical and high vulnerabilities, and set to default on medium, low, and informational vulnerabilities (Scored) 104

6.8 Ensure a secure Vulnerability Protection Profile is applied to all security rules allowing traffic (Scored) 105

6.9 Ensure that PAN-DB URL Filtering is used (Scored) 107

6.10 Ensure that URL Filtering uses the action of “block” or “override” on the URL categories (Scored) 109

6.11 Ensure that access to every URL is logged (Scored) 110

6.12 Ensure all HTTP Header Logging options are enabled (Scored) 111

6.13 Ensure secure URL filtering is enabled for all security policies allowing traffic to the Internet (Scored) 113

6.14 Ensure alerting after a threshold of credit card or Social Security numbers is detected is enabled (Scored) 115

6.15 Ensure a secure Data Filtering profile is applied to all security policies allowing traffic to or from the Internet (Scored) 117

6.16 Ensure that a Zone Protection Profile with an enabled SYN Flood Action of SYN Cookies is attached to all untrusted zones (Scored) 119

6.17 Ensure that a Zone Protection Profile with tuned Flood Protection settings enabled for all flood types is attached to all untrusted zones (Scored) 121

6.18 Ensure that all zones have Zone Protection Profiles with all Reconnaissance Protection settings enabled, tuned, and set to appropriate actions (Scored) 123

6.19 Ensure all zones have Zone Protection Profiles that drop specially crafted packets (Scored) 125

7 Security Policies 127

7.1 Ensure application security policies exist when allowing traffic from an untrusted zone to a more trusted zone (Scored) 127

7.2 Ensure 'Service setting of ANY' in a security policy allowing traffic does not exist (Scored) 129

ARCHIVE

7.3 Ensure 'Security Policy' denying any/all traffic exists at the bottom of the security policies ruleset (Scored) 131
8 Decryption 133
8.1 Ensure 'SSL Forward Proxy Policy' for traffic destined to the Internet is configured (Scored) 133
8.2 Ensure 'SSL Inbound Inspection' is required for all untrusted traffic destined for servers using SSL or TLS (Scored) 135
8.3 Ensure that the Certificate used for Decryption is Trusted (Not Scored) 136
Appendix: Summary Table 139
Appendix: Change History 143

ARCHIVE

Overview

This document provides prescriptive guidance for establishing a secure configuration posture for Palo Alto Firewalls running PAN-OS version 6.1. This guide was tested against PAN-OS v6.1. To obtain the latest version of this guide, please visit http://benchmarks.cisecurity.org. If you have questions, comments, or have identified ways to improve this guide, please write us at feedback@cisecurity.org.

Intended Audience

This benchmark is intended for system and application administrators, security specialists, auditors, help desk, and platform deployment personnel who plan to develop, deploy, assess, or secure solutions that incorporate PAN-OS on a Palo Alto Firewall

Consensus Guidance

This benchmark was created using a consensus review process comprised of subject matter experts. Consensus participants provide perspective from a diverse set of backgrounds including consulting, software development, audit and compliance, security research, operations, government, and legal.

Each CIS benchmark undergoes two phases of consensus review. The first phase occurs during initial benchmark development. During this phase, subject matter experts convene to discuss, create, and test working drafts of the benchmark. This discussion occurs until consensus has been reached on benchmark recommendations. The second phase begins after the benchmark has been published. During this phase, all feedback provided by the Internet community is reviewed by the consensus team for incorporation in the benchmark. If you are interested in participating in the consensus process, please visit https://community.cisecurity.org.

ARCHIVE

Typographical Conventions

The following typographical conventions are used throughout this guide:

Convention	Meaning
`Stylized Monospace font`	Used for blocks of code, command, and script examples. Text should be interpreted exactly as presented.
Monospace font	Used for inline code, commands, or examples. Text should be interpreted exactly as presented.
<italic font in brackets>	Italic texts set in angle brackets denote a variable requiring substitution for a real value.
Italic font	Used to denote the title of a book, article, or other publication.
Note	Additional information or caveats

Scoring Information

A scoring status indicates whether compliance with the given recommendation impacts the assessed target's benchmark score. The following scoring statuses are used in this benchmark:

Scored

Failure to comply with "Scored" recommendations will decrease the final benchmark score. Compliance with "Scored" recommendations will increase the final benchmark score.

Not Scored

Failure to comply with "Not Scored" recommendations will not decrease the final benchmark score. Compliance with "Not Scored" recommendations will not increase the final benchmark score.

ARCHIVE

Profile Definitions

The following configuration profiles are defined by this Benchmark:

- **Level 1**

  Items in this profile intend to:

  - be practical and prudent;
  - provide a clear security benefit; and
  - not negatively inhibit the utility of the technology beyond acceptable means.

- **Level 2**

  This profile extends the "Level 1" profile. Items in this profile exhibit one or more of the following characteristics:

  - are intended for environments or use cases where security is paramount
  - acts as defense in depth measure
  - may negatively inhibit the utility or performance of the technology.

ARCHIVE

Acknowledgements

This benchmark exemplifies the great things a community of users, vendors, and subject matter experts can accomplish through consensus collaboration. The CIS community thanks the entire consensus team with special recognition to the following individuals who contributed greatly to the creation of this guide:

Author
Ryan Firth CISSP, CCNP, CISA, GCIH, GLEG

Contributor
Jordan Rakoske
Jeff Mathis PAN-ACE, SFCAR, JNCIP-ENT, JNCIS-SEC, CCNA, SFCE, SFCE-AMP, Network+
Adam Winnington
Raymond Winder PAN-ACE, GCED, GCIH, BS
Samshodh Sunku, Palo Alto

Editor
Derek Ho
Rob VandenBrink
Karen Scarfone

ARCHIVE

Recommendations

1 Device Setup

The Device Setup section covers requirements for login banners, logging, management interfaces, password strength, device management authentication, SNMP polling, and device services.

ARCHIVE

1.1 General Settings

The General settings section includes banner and logging requirement settings.

1.1.1 Ensure 'Login Banner' is set (Scored)

Profile Applicability:

- Level 1

Description:

Configure a login banner, ideally approved by the organization's legal team. This banner should, at minimum, prohibit unauthorized access, provide notice of logging or monitoring, and avoid using the word "welcome" or similar words of invitation.

Rationale:

Through a properly stated login banner, the risk of unintentional access to the device by unauthorized users is reduced. Should legal action take place against a person accessing the device without authorization, the login banner greatly diminishes a defendant's claim of ignorance.

Audit:

Navigate to `Device > Setup > Management > General Settings`.

Verify `Login Banner` is set appropriately.

or

Execute the following CLI command to verify a login banner is configured:

```
username@hostname#show deviceconfig system | match login-banner
```

Remediation:

Navigate to `Device > Setup > Management > General Settings`.

Set `Login Banner` as appropriate.

or

To remediate this setting using the CLI, execute the following command:

```
username@hostname#set deviceconfig system login-banner <value>
```

ARCHIVE

Default Value:

Not configured

References:

1. "How to Configure the Device Login Banner" - https://live.paloaltonetworks.com/docs/DOC-7964

ARCHIVE

1.1.2 Ensure 'Enable Log on High DP Load' is enabled (Scored)

Profile Applicability:

- Level 1

Description:

Enable the option 'Enable Log on High DP Load' feature. When this option is selected, a system log entry is created when the device's packet processing load reaches 100% utilization.

Rationale:

When the device's packet processing load reaches 100%, a degradation in the availability of services accessed through the device can occur. Logging this event can help with troubleshooting system performance.

Audit:

Navigate to `Device > Setup > Management > Logging and Reporting Settings`.

Verify `Enable Log on High DP Load` is checked.

or

Execute the following CLI command to verify DP load log settings:

```
username@hostname#show deviceconfig setting | match enable-log-high-dp-load
```

Remediation:

Navigate to `Device > Setup > Management > Logging and Reporting Settings`.

Set the `Enable Log on High DP Load` box to checked.

or

To remediate this setting using the CLI, execute the following command:

```
 username@hostname#set deviceconfig setting management enable-log-high-dp-load yes
```

Default Value:

Not enabled

ARCHIVE

References:

1. https://live.paloaltonetworks.com/docs/DOC-4075

ARCHIVE

1.2 Management Interface Settings

The Management Interface settings include restrictions on how management interfaces are accessed, secured, and used.

1.2.1 Ensure 'Permitted IP Addresses' is set to those necessary for device management (Scored)

Profile Applicability:

- Level 1

Description:

Permit only the necessary IP addresses to be used to manage the device.

Rationale:

Management access to the device should be restricted to the IP addresses used by firewall administrators. Permitting management access from other IP addresses increases the risk of unauthorized access through password guessing, stolen credentials, or other means.

Audit:

Navigate to `Device > Setup > Management > Management Interface Settings`.

Verify `Permitted IP Addresses` is limited to those necessary for device management.

or

Execute the following CLI command to verify that all IP addresses listed for the setting are approved for device management:

```
username@hostname#run show interface management
```

Remediation:

Navigate to `Device > Setup > Management > Management Interface Settings`.

Set `Permitted IP Addresses` to only those necessary for device management.

or

To remediate this setting using the CLI, execute the following command:

```
username@hostname#set deviceconfig system permitted-ip <ipaddress/netmask>
```

ARCHIVE

```
username@hostname#commit
```

Default Value:

Not enabled

References:

1. https://live.paloaltonetworks.com/docs/DOC-8432

ARCHIVE

1.2.2 Ensure 'Permitted IP Addresses' is set for all management profiles where SSH, HTTPS, or SNMP is enabled (Scored)

Profile Applicability:

- Level 1

Description:

For all management profiles, only the IP addresses required for device management should be specified.

Rationale:

If a Permitted IP Addresses list is either not specified or is too broad, an attacker may gain the ability to attempt management access from unintended locations, such as the Internet. The "Ensure 'Security Policy' denying any/all traffic exists at the bottom of the security policies ruleset" recommendation in this benchmark can provide additional protection by requiring a security policy specifically allowing device management access.

Audit:

Navigate to `Network > Network Profiles > Interface Management`.

Verify `Permitted IP Addresses` is limited to those necessary for device management.

Remediation:

Navigate to `Network > Network Profiles > Interface Management`.

Set `Permitted IP Addresses` to only include those necessary for device management.

or

To remediate this setting using the CLI, execute the following commands:

```
username@hostname#set network profiles interface-management-profile  permitted-ip
username@hostname#commit
```

Default Value:

Not enabled

References:

1. https://live.paloaltonetworks.com/docs/DOC-8432

ARCHIVE

1.2.3 Ensure HTTP and Telnet options are disabled for the Management Interface (Scored)

Profile Applicability:

- Level 1

Description:

HTTP and Telnet options should not be enabled for device management.

Rationale:

Management access over cleartext services such as HTTP or Telnet could result in a compromise of administrator credentials and other sensitive information related to device management.

Audit:

Navigate to `Device > Setup > Management > Management Interface Settings`.

Verify that the `HTTP` and `Telnet` options are both unchecked.

Remediation:

Navigate to `Device > Setup > Management > Management Interface Settings`.

Set the `HTTP` and `Telnet` boxes to unchecked.

Default Value:

Not set.

References:

1. https://live.paloaltonetworks.com/docs/DOC-2005

ARCHIVE

1.2.4 Ensure valid certificate is set for browser-based administrator interface (Not Scored)

Profile Applicability:

- Level 2

Description:

In most cases, a browser HTTPS interface is used to administer the Palo Alto appliance. The certificate used to secure this session should satisfy the following criteria:

1. A valid certificate from a trusted source should be used. While a certificate from a trusted Public Certificate Authority is certainly valid, one from a trusted Private Certificate Authority is absolutely acceptable for this purpose.
2. The certificate should have a valid date. It should not have a "to" date in the past (it should not be expired), and should not have a "from" date in the future.
3. The certificate should use an acceptable cipher and encryption level.

Rationale:

If a certificate that is self-signed, expired, or otherwise invalid is used for the browser HTTPS interface, administrators in most cases will not be able to tell if their session is being eavesdropped on or injected into by a "Man in the Middle" attack.

Audit:

Verify that the certificate used to secure HTTPS sessions meets the criteria by reviewing the appropriate certificate:

Navigate to `Device` > `Setup` > `Certificate Management` > `Certificates`

Verify that there is an appropriately named Certificate Profile for Management Interface Access:

`Navigate to Device` > `Setup` > `Certificate Management` > `Certificate Profile`

Verify that the Authentication Profile field contains the Certificate Profile created for Management Interface Access:

`Navigate to Device` > `Setup` > `Management (tab)` > `Authentication Settings` > `Authentication Profile (field)`

ARCHIVE

Remediation:

If a new administrative certificate is needed, acquire a certificate that meets the stated criteria and set it:

`Navigate to Device > Setup > Certificate Management > Certificates`

Set an appropriately named Certificate Profile for Management Interface Access:

`Navigate to Device > Setup > Certificate Management > Certificate Profile`

Set the Authentication Profile field so it contains the Certificate Profile created for Management Interface Access:

`Navigate to Device > Setup > Management (tab) > Authentication Settings > Authentication Profile (field)`

Default Value:

A self-signed certificate is installed by default for the administrative interface.

ARCHIVE

1.3 Minimum Password Requirements

The Minimum Password Requirements Section contains password criteria such as complexity and restrictions.

1.3.1 Ensure 'Minimum Password Complexity' is enabled (Scored)

Profile Applicability:

- Level 1

Description:

This checks all new passwords to ensure that they meet basic requirements for strong passwords.

Rationale:

Password complexity recommendations are derived from the USGCB (United States Government Configuration Baseline), Common Weakness Enumeration, and benchmarks published by the CIS (Center for Internet Security).

Audit:

Navigate to `Device > Setup > Management > Minimum Password Complexity`.

Verify `Enabled` is checked

or

Execute the following CLI command:

```
 username@hostname#show mgt-config password-complexity
```

Remediation:

Navigate to `Device > Setup > Management > Minimum Password Complexity`.

Set `Enabled` to be checked

or

Execute the following CLI command:

```
 username@hostname#set mgt-config password-complexity
+ block-repeated-characters            Block repeated characters count
+ block-username-inclusion             Block inclusion of username and it's reverse
```

ARCHIVE

```
+ enabled                                Enable minimal password complexity enforcement
+ minimum-length                         Minimum password length
+ minimum-lowercase-letters              Minimum lowercase letters in the password
+ minimum-numeric-letters                Minimum numeric(0-9) letters in the password
+ minimum-special-characters             Minimum special characters(non-alphanumeric) in
the password
+ minimum-uppercase-letters              Minimum uppercase letters in the password
+ new-password-differs-by-characters     New Password must differ by the count chars
+ password-change-on-first-login         Password must change on first time login
+ password-change-period-block           Password change block period
+ password-history-count                 Save password history for password changes
> password-change                       password-change
  <Enter>                                Finish input
# commit
```

Default Value:

Not enabled.

ARCHIVE

1.3.2 Ensure 'Minimum Length' is greater than or equal to 12 (Scored)

Profile Applicability:

- Level 1

Description:

This determines the least number of characters that make up a password for a user account.

Rationale:

Types of password attacks include dictionary attacks (which attempt to use common words and phrases) and brute force attacks (which try every possible combination of characters).

Audit:

Navigate to `Device > Setup > Management > Minimum Password Complexity`.

Verify `Minimum Length` is greater than or equal to `12`

or

Execute the following CLI command:

```
 username@hostname#show mgt-config password-complexity | match minimum-length
```

Remediation:

Navigate to `Device > Setup > Management > Minimum Password Complexity`.

Set `Minimum Length` to greater than or equal to `12`

or

Execute the following CLI command:

```
 username@hostname#set mgt-config password-complexity minimum-length <>
+ block-repeated-characters            Block repeated characters count
+ block-username-inclusion             Block inclusion of username and it's reverse
+ enabled                              Enable minimal password complexity enforcement
+ minimum-length                       Minimum password length
+ minimum-lowercase-letters            Minimum lowercase letters in the password
+ minimum-numeric-letters              Minimum numeric(0-9) letters in the password
+ minimum-special-characters           Minimum special characters(non-alphanumeric) in
the password
+ minimum-uppercase-letters            Minimum uppercase letters in the password
+ new-password-differs-by-characters   New Password must differ by the count chars
+ password-change-on-first-login       Password must change on first time login
```

ARCHIVE

```
+ password-change-period-block          Password change block period
+ password-history-count                Save password history for password changes
> password-change                       password-change
  <Enter>                               Finish input
# commit
```

Default Value:

Not enabled.

ARCHIVE

1.3.3 Ensure 'Prevent Password Reuse Limit' is set to 24 or more passwords (Scored)

Profile Applicability:

- Level 1

Description:

This determines the number of unique passwords that have to be most recently used for a user account before a previous password can be reused.

Rationale:

The longer a user uses the same password, the greater the chance that an attacker can determine the password through brute force attacks. Also, any accounts that may have been compromised will remain exploitable for as long as the password is left unchanged. If password changes are required but password reuse is not prevented, or if users continually reuse a small number of passwords, the effectiveness of a good password policy is greatly reduced.

Audit:

Navigate to `Device > Setup > Management > Minimum Password Complexity`.

Verify `Prevent Password Reuse Limit` is greater than or equal to `24`

or

Execute the following CLI command:

```
username@hostname#show mgt-config password-complexity | match password-history-count
```

Remediation:

Navigate to `Device > Setup > Management > Minimum Password Complexity`.

Set `Prevent Password Reuse Limit` to greater than or equal to `24`

or

Execute the following CLI command:

```
 username@set mgt-config password-complexity password-history-count <>
+ block-repeated-characters            Block repeated characters count
+ block-username-inclusion             Block inclusion of username and it's reverse
```

ARCHIVE

```
+ enabled                                Enable minimal password complexity enforcement
+ minimum-length                         Minimum password length
+ minimum-lowercase-letters              Minimum lowercase letters in the password
+ minimum-numeric-letters                Minimum numeric(0-9) letters in the password
+ minimum-special-characters             Minimum special characters(non-alphanumeric) in
the password
+ minimum-uppercase-letters              Minimum uppercase letters in the password
+ new-password-differs-by-characters     New Password must differ by the count chars
+ password-change-on-first-login         Password must change on first time login
+ password-change-period-block           Password change block period
+ password-history-count                 Save password history for password changes
> password-change                       password-change
  <Enter>                                Finish input
# commit
```

Default Value:

Not enabled.

ARCHIVE

1.3.4 Ensure 'Required Password Change Period' is less than or equal to 90 days (Scored)

Profile Applicability:

- Level 1

Description:

This defines how long a user can use a password before it expires.

Rationale:

The longer a password exists, the higher the likelihood that it will be compromised by a brute force attack, by an attacker gaining general knowledge about the user and guessing the password, or by the user sharing the password.

Audit:

Navigate to `Device > Setup > Management > Minimum Password Complexity`.

Verify `Required Password Change Period (days)` is less than or equal to `90`

or

Execute the following CLI command:

```
 username@hostname#show mgt-config password-complexity
```

Remediation:

Navigate to `Device > Setup > Management > Minimum Password Complexity`.

Set `Required Password Change Period (days)` to less than or equal to `90`

or

Execute the following CLI command:

```
 username@hostname#set mgt-config password-complexity
+ block-repeated-characters            Block repeated characters count
+ block-username-inclusion             Block inclusion of username and it's reverse
+ enabled                              Enable minimal password complexity enforcement
+ minimum-length                       Minimum password length
+ minimum-lowercase-letters            Minimum lowercase letters in the password
+ minimum-numeric-letters              Minimum numeric(0-9) letters in the password
+ minimum-special-characters           Minimum special characters(non-alphanumeric) in
the password
+ minimum-uppercase-letters            Minimum uppercase letters in the password
```

ARCHIVE

```
+ new-password-differs-by-characters   New Password must differ by the count chars
+ password-change-on-first-login       Password must change on first time login
+ password-change-period-block         Password change block period
+ password-history-count               Save password history for password changes
> password-change                      password-change
  <Enter>                              Finish input
# commit
```

Default Value:

Not enabled.

References:

1. https://www.paloaltonetworks.com/documentation/60/panorama/panorama_adminguide/administer-panorama/configure-password-profiles-and-password-complexity.html

ARCHIVE

1.3.5 Ensure 'Password Profiles' do not exist (Scored)

Profile Applicability:

- Level 1

Description:

Password profiles that are weaker than the recommended minimum password complexity settings must not exist.

Rationale:

As password profiles override any 'Minimum Password Complexity' settings defined in the device, they generally should not exist. If these password profiles do exist, they should enforce stronger password policies than what is set in the 'Minimum Password Complexity' settings.

Audit:

Navigate to `Device > Password Profiles`.

Verify Password Profiles weaker than the recommended minimum password complexity settings do not exist.

or

Execute the following CLI command:

```
username@hostname#show mgt-config password-profile
```

Remediation:

Navigate to `Device > Password Profiles`.

Ensure Password Profiles weaker than the recommended minimum password complexity settings do not exist.

or

Execute the following CLI command:

```
username@hostname#set mgt-config password-profile <none>
```

Default Value:

Not configured

ARCHIVE

References:

1. PAN-OS 6.1 Administrator's Guide pg.53

ARCHIVE

1.3.6 Ensure 'Minimum Uppercase Letters' is greater than or equal to 1 (Scored)

Profile Applicability:

- Level 1

Description:

This checks all new passwords to ensure that they contain at least one English uppercase character (A through Z).

Rationale:

This is one of several settings that, when taken together, ensure that passwords are sufficiently complex as to thwart brute force and dictionary attacks.

Audit:

Navigate to `Device` > `Setup` > `Management` > `Minimum Password Complexity`
Verify `Minimum Uppercase Letters` is greater than or equal to `1`

or

Execute the following CLI command:

```
 username@hostname#show mgt-config password-complexity
```

Remediation:

Navigate to `Device` > `Setup` > `Management` > `Minimum Password Complexity`
Set `Minimum Uppercase Letters` to greater than or equal to `1`

or

Execute the following CLI command:

```
 username@hostname#set mgt-config password-complexity
+ block-repeated-characters            Block repeated characters count
+ block-username-inclusion             Block inclusion of username and it's reverse
+ enabled                              Enable minimal password complexity enforcement
+ minimum-length                       Minimum password length
+ minimum-lowercase-letters            Minimum lowercase letters in the password
+ minimum-numeric-letters              Minimum numeric(0-9) letters in the password
+ minimum-special-characters           Minimum special characters(non-alphanumeric) in
the password
+ minimum-uppercase-letters            Minimum uppercase letters in the password
+ new-password-differs-by-characters   New Password must differ by the count chars
+ password-change-on-first-login       Password must change on first time login
```

ARCHIVE

```
+ password-change-period-block          Password change block period
+ password-history-count                Save password history for password changes
> password-change                       password-change
  <Enter>                               Finish input
# commit
```

Default Value:

Not enabled.

ARCHIVE

1.3.7 Ensure 'Minimum Lowercase Letters' is greater than or equal to 1 (Scored)

Profile Applicability:

- Level 1

Description:

This checks all new passwords to ensure that they contain at least one English lowercase character (a through z).

Rationale:

This is one of several settings that, when taken together, ensure that passwords are sufficiently complex as to thwart brute force and dictionary attacks.

Audit:

Navigate to `Device` > `Setup` > `Management` > `Minimum Password Complexity`
Verify `Minimum Lowercase Letters` is greater than or equal to `1`

or

Execute the following CLI command:

```
 username@hostname#show mgt-config password-complexity
```

Remediation:

Navigate to `Device` > `Setup` > `Management` > `Minimum Password Complexity`
Set `Minimum Lowercase Letters` to greater than or equal to `1`

or

Execute the following CLI command:

```
 username@hostname#set mgt-config password-complexity
+ block-repeated-characters            Block repeated characters count
+ block-username-inclusion             Block inclusion of username and it's reverse
+ enabled                              Enable minimal password complexity enforcement
+ minimum-length                       Minimum password length
+ minimum-lowercase-letters            Minimum lowercase letters in the password
+ minimum-numeric-letters              Minimum numeric(0-9) letters in the password
+ minimum-special-characters           Minimum special characters(non-alphanumeric) in
the password
+ minimum-uppercase-letters            Minimum uppercase letters in the password
+ new-password-differs-by-characters   New Password must differ by the count chars
+ password-change-on-first-login       Password must change on first time login
```

ARCHIVE

```
+ password-change-period-block          Password change block period
+ password-history-count                Save password history for password changes
> password-change                       password-change
  <Enter>                               Finish input
# commit
```

Default Value:

Not enabled.

ARCHIVE

1.3.8 Ensure 'Minimum Numeric Letters' is greater than or equal to 1 (Scored)

Profile Applicability:

- Level 1

Description:

This checks all new passwords to ensure that they contain at least one base 10 digit (0 through 9).

Rationale:

This is one of several settings that, when taken together, ensure that passwords are sufficiently complex as to thwart brute force and dictionary attacks.

Audit:

Navigate to `Device` > `Setup` > `Management` > `Minimum Password Complexity`
Verify `Minimum Numeric Letters` is greater than or equal to `1`

or

Execute the following CLI command:

```
 username@hostname#show mgt-config password-complexity
```

Remediation:

Navigate to `Device` > `Setup` > `Management` > `Minimum Password Complexity`
Set `Minimum Numeric Letters` to greater than or equal to `1`

or

Execute the following CLI command:

```
 username@hostname#set mgt-config password-complexity
+ block-repeated-characters            Block repeated characters count
+ block-username-inclusion             Block inclusion of username and it's reverse
+ enabled                              Enable minimal password complexity enforcement
+ minimum-length                       Minimum password length
+ minimum-lowercase-letters            Minimum lowercase letters in the password
+ minimum-numeric-letters              Minimum numeric(0-9) letters in the password
+ minimum-special-characters           Minimum special characters(non-alphanumeric) in
the password
+ minimum-uppercase-letters            Minimum uppercase letters in the password
+ new-password-differs-by-characters   New Password must differ by the count chars
+ password-change-on-first-login       Password must change on first time login
```

ARCHIVE

```
+ password-change-period-block          Password change block period
+ password-history-count                Save password history for password changes
> password-change                       password-change
  <Enter>                               Finish input
# commit
```

Default Value:

Not enabled.

ARCHIVE

1.3.9 Ensure 'Minimum Special Characters' is greater than or equal to 1 (Scored)

Profile Applicability:

- Level 1

Description:

This checks all new passwords to ensure that they contain at least one non-alphabetic character (for example, !, $, #, %).

Rationale:

This is one of several settings that, when taken together, ensure that passwords are sufficiently complex as to thwart brute force and dictionary attacks.

Audit:

Navigate to `Device` > `Setup` > `Management` > `Minimum Password Complexity`
Verify `Minimum Special Characters` is greater than or equal to `1`

or

Execute the following CLI command:

```
 username@hostname#show mgt-config password-complexity
```

Remediation:

Navigate to `Device` > `Setup` > `Management` > `Minimum Password Complexity`
Set `Minimum Special Characters` to greater than or equal to `1`

or

Execute the following CLI command:

```
 username@hostname#set mgt-config password-complexity
+ block-repeated-characters            Block repeated characters count
+ block-username-inclusion             Block inclusion of username and it's reverse
+ enabled                              Enable minimal password complexity enforcement
+ minimum-length                       Minimum password length
+ minimum-lowercase-letters            Minimum lowercase letters in the password
+ minimum-numeric-letters              Minimum numeric(0-9) letters in the password
+ minimum-special-characters           Minimum special characters(non-alphanumeric) in
the password
+ minimum-uppercase-letters            Minimum uppercase letters in the password
+ new-password-differs-by-characters   New Password must differ by the count chars
+ password-change-on-first-login       Password must change on first time login
```

ARCHIVE

```
+ password-change-period-block         Password change block period
+ password-history-count               Save password history for password changes
> password-change                      password-change
  <Enter>                              Finish input
# commit
```

Default Value:

Not enabled.

ARCHIVE

1.3.10 Ensure 'Block Username Inclusion' is enabled (Scored)

Profile Applicability:

- Level 1

Description:

This checks all new passwords to ensure that they block username inclusion (in either forward or reverse order.)

Rationale:

This is one of several settings that, when taken together, ensure that passwords are sufficiently complex as to thwart brute force and dictionary attacks.

Audit:

Navigate to `Device > Setup > Management > Minimum Password Complexity`
Verify `Block Username Inclusion (Including reversed)` is checked

or

Execute the following CLI command:

```
 username@hostname#show mgt-config password-complexity
```

Remediation:

Navigate to `Device` > `Setup` > `Management` > `Minimum Password Complexity`
Set `Block Username Inclusion (Including reversed)` to checked

or

Execute the following CLI command:

```
 username@hostname#set mgt-config password-complexity
+ block-repeated-characters            Block repeated characters count
+ block-username-inclusion             Block inclusion of username and it's reverse
+ enabled                              Enable minimal password complexity enforcement
+ minimum-length                       Minimum password length
+ minimum-lowercase-letters            Minimum lowercase letters in the password
+ minimum-numeric-letters              Minimum numeric(0-9) letters in the password
+ minimum-special-characters           Minimum special characters(non-alphanumeric) in
the password
+ minimum-uppercase-letters            Minimum uppercase letters in the password
+ new-password-differs-by-characters   New Password must differ by the count chars
+ password-change-on-first-login       Password must change on first time login
+ password-change-period-block         Password change block period
+ password-history-count               Save password history for password changes
```

ARCHIVE

```
> password-change                        password-change
  <Enter>                                Finish input
# commit
```

Default Value:

Not enabled.

ARCHIVE

1.3.11 Ensure 'New Password Differs by Characters' is greater than or equal to 3 (Scored)

Profile Applicability:

- Level 1

Description:

This checks all new passwords to ensure that they differ by at least three characters from the previous password.

Rationale:

This is one of several settings that, when taken together, ensure that passwords are sufficiently complex as to thwart brute force and dictionary attacks.

Audit:

Navigate to `Device` > `Setup` > `Management` > `Minimum Password Complexity`
Verify `New Password Differs By Characters` is set to greater than or equal to 3

or

Execute the following CLI command:

```
 username@hostname#show mgt-config password-complexity
```

Remediation:

Navigate to `Device` > `Setup` > `Management` > `Minimum Password Complexity`
Set `New Password Differs By Characters` to 3 or more

or

Execute the following CLI command:

```
 username@hostname#set mgt-config password-complexity
+ block-repeated-characters            Block repeated characters count
+ block-username-inclusion             Block inclusion of username and it's reverse
+ enabled                              Enable minimal password complexity enforcement
+ minimum-length                       Minimum password length
+ minimum-lowercase-letters            Minimum lowercase letters in the password
+ minimum-numeric-letters              Minimum numeric(0-9) letters in the password
+ minimum-special-characters           Minimum special characters(non-alphanumeric) in
the password
+ minimum-uppercase-letters            Minimum uppercase letters in the password
+ new-password-differs-by-characters   New Password must differ by the count chars
+ password-change-on-first-login       Password must change on first time login
```

ARCHIVE

```
+ password-change-period-block          Password change block period
+ password-history-count                Save password history for password changes
> password-change                       password-change
  <Enter>                               Finish input
# commit
```

Default Value:

Not enabled.

ARCHIVE

1.4 Authentication Settings (for Device Mgmt)

The Authentication Settings Section contains Idle Timeout values and requirements for Authentication Profiles.

1.4.1 Ensure 'Idle timeout' is less than or equal to 10 minutes for device management (Scored)

Profile Applicability:

- Level 1

Description:

Set the Idle Timeout value for device management to 10 minutes or less to automatically close inactive sessions.

Rationale:

An unattended computer with an open administrative session to the device could allow an unauthorized user access to the firewall's management interface.

Audit:

Navigate to `Device > Setup > Management > Authentication Settings`.

Verify `Idle Timeout` is less than or equal to `10`.

or

Execute the following CLI command to verify this setting:

```
username@hostname#show deviceconfig setting management | match idle-timeout
```

Remediation:

Navigate to `Device > Setup > Management > Authentication Settings`.

Set `Idle Timeout` to less than or equal to `10`.

or

To remediate this setting, execute the following CLI command:

```
username@hostname#set deviceconfig setting management idle-timeout <value>
```

ARCHIVE

Default Value:

Not configured

References:

1. "How to Change the Admin Session Timeout Value" - https://live.paloaltonetworks.com/docs/DOC-5557

ARCHIVE

1.4.2 Ensure 'Failed Attempts' and 'Lockout Time' for Authentication Profile are properly configured (Scored)

Profile Applicability:

- Level 1

Description:

Configure an Authentication Profile with Failed Attempts and Lockout Time set to organization-defined values (for example, 3 failed attempts and a 15 minute lockout time). Do not set Failed Attempts and Lockout Time in the Authentication Settings section; any Failed Attempts or Lockout Time settings within the selected Authentication Profile do not apply in the Authentication Settings section.

Rationale:

Without a lockout limit, an attacker can continuously guess administrators' passwords. If lockout settings are configured in the Authentication Settings section, it may be possible for an attacker to continuously lock out all administrative accounts from accessing the device.

Audit:

Navigate to `Device > Authentication Profile`.

Verify `Failed Attempts` is set to the organization-defined value.

Verify `Lockout Time` is set to the organization-defined value.

or

Execute the following CLI commands:

```
username@hostname#show deviceconfig setting management | match lockout
username@hostname#show deviceconfig setting management | match attempts
```

Remediation:

Navigate to `Device > Authentication Profile`.

Set `Failed Attempts` to the organization-defined value.

Set `Lockout Time` to the organization-defined value.

or

ARCHIVE

Execute the following CLI commands:

```
username@hostname#set deviceconfig setting management admin-lockout failed-attempts
username@hostname#set deviceconfig setting management admin-lockout lockout-time
```

Default Value:

Not configured

References:

1. PAN-OS 6.1 Administrator's Guide pg.68

ARCHIVE

1.5 SNMP Polling Settings

SNMP polling sets out requirements for using SNMP.

1.5.1 Ensure 'V3' is selected for SNMP polling (Scored)

Profile Applicability:

- Level 1

Description:

For SNMP polling, only SNMPv3 should be used.

Rationale:

SNMPv3 utilizes AES-128 encryption, message integrity, user authorization, and device authentication security features. SNMPv2c does not provide these security features. If an SNMPv2c community string is intercepted or otherwise obtained, an attacker could gain read access to the firewall. Note that SNMP write access is not possible.

Audit:

Navigate to `Device > Setup > Operations > Miscellaneous > SNMP Setup`

Verify `V3` is selected.

or

Execute the following CLI command to verify SNMPv3 is configured:

```
username@hostname#show deviceconfig system snmp-setting
```

Remediation:

Navigate to `Device > Setup > Operations > Miscellaneous > SNMP Setup`

Select `V3`.

or

To remediate this setting, execute the following CLI command:

```
username@hostname#set deviceconfig system snmp-setting access-setting version v3
```

ARCHIVE

Default Value:

Not configured

References:

1. "How to Setup SNMPv3 Polling" - https://live.paloaltonetworks.com/docs/DOC-4037
2. "Using the Simple Network Management Protocol (SNMP)" - https://live.paloaltonetworks.com/docs/DOC-4627
3. PAN-OS-6.1-CLI-ref.pdf

ARCHIVE

1.6 Device Services Settings

The Device Services Settings section contains requirements for verifying the update server's identity, enabling redundant NTP services, and using a valid certificate for securing VPN remote access.

1.6.1 Ensure 'Verify Update Server Identity' is enabled (Scored)

Profile Applicability:

- Level 1

Description:

This setting determines whether or not the identity of the update server must be verified before performing an update session.

Note that if an SSL Forward Proxy is configured to intercept the update session, this option may need to be disabled.

Rationale:

Verifying the update server identity before package download ensures the packages originate from a trusted source. Without this, it is possible to receive and install an update from a malicious source.

Audit:

Navigate to `Device > Setup > Services > Services`.

Verify that the `Verify Update Server Identity` box is checked.

or

Execute the following CLI command to verify the setting:

```
username@hostname>show deviceconfig system | match server-verification
```

Remediation:

Navigate to `Device > Setup > Services > Services`.

Set the `Verify Update Server Identity` box to checked.

or

ARCHIVE

To remediate this setting, execute the following CLI command:

```
username@hostname#set deviceconfig system server-verification yes
```

Default Value:

Not configured

ARCHIVE

1.6.2 Ensure redundant NTP servers are configured appropriately (Scored)

Profile Applicability:

- Level 1

Description:

These settings enable use of primary and secondary NTP servers to provide redundancy in case of a failure involving the primary NTP server.

Rationale:

NTP enables the device to maintain an accurate time and date when receiving updates from a reliable NTP server. Accurate timestamps are critical when correlating events with other systems, troubleshooting, or performing investigative work. Logs and certain cryptographic functions, such as those utilizing certificates, rely on accurate time and date parameters. In addition, rules referencing a Schedule object will not function as intended if the device's time and date are incorrect.

For additional security, authenticated NTP can be utilized. If Symmetric Key is selected, only SHA1 should be used as MD5 is considered severely compromised.

Audit:

Navigate to `Device > Setup > Services > Services`.

Verify `Primary NTP Server Address` is set appropriately.

Verify `Secondary NTP Server Address` is set appropriately.

or

Execute the following CLI command to verify that both primary and secondary NTP Servers are configured:

```
username@hostname>show deviceconfig system ntp-servers
```

Remediation:

Navigate to `Device > Setup > Services > Services`.

Set `Primary NTP Server Address` appropriately.

ARCHIVE

Set `Secondary NTP Server Address` appropriately.

or

To remediate these settings, execute the following CLI commands:

```
username@hostname#set deviceconfig system ntp-servers primary-ntp-server
username@hostname#set deviceconfig system ntp-servers secondary-ntp-server
```

Default Value:

Not configured

References:

1. "The NIST Authenticated NTP Service" - http://www.nist.gov/pml/div688/grp40/authntp.cfm
2. "PAN-OS Administrator's Guide 6.1 (English)" - https://www.paloaltonetworks.com/documentation/61/pan-os/pan-

ARCHIVE

1.6.3 Ensure that the certificate securing Remote Access VPNs is valid (Not Scored)

Profile Applicability:

- Level 1
- Level 2

Description:

The Certificate used to secure Remote Access VPNs should satisfy the following criteria:

- It should be a valid certificate from a trusted source. In almost cases this means a trusted Public Certificate Authority, as in most cases remote access VPN users will not have access to any Private Certificate Authorities for Certificate validation.
- The certificate should have a valid date. It should not have a "to" date in the past (it should not be expired), and should not have a "from" date in the future.
- The key length used to encrypt the certificate should be 2048 bits or more.
- The hash used to sign the certificate should be SHA-2 or better.

Rationale:

If presented with a certificate error, the end user in most cases will not be able to tell if their session is using a self-signed or expired certificate, or if their session is being eavesdropped on or injected into by a "Man in the Middle" attack.

Audit:

Verify that the certificate being used to secure the VPN meets the criteria listed above:
Navigate to `Device` > `Management` > `Certificate Management` > `Certificates`

Ensure that a valid certificate is applied to the HTTPS portal:
Navigate to `Network` > `GlobalProtect` > `Portals` > `Portal Configuration` > `Server Certificate`

Ensure that a valid certificate is applied to the GlobalProtect Gateway:
Navigate to `Network` > `GlobalProtect` > `Gateways` > `General` > `Server Certificate`

Remediation:

Create a CSR and install a certificate from a public CA here:
Navigate to `Device` > `Management` > `Certificate Management` > `Certificates`

ARCHIVE

Apply a valid certificate to the HTTPS portal:
Navigate to `Network` > `GlobalProtect` > `Portals` > `Portal Configuration` > `Server Certificate`

Apply a valid certificate to the GlobalProtect Gateway:
Navigate to `Network` > `GlobalProtect` > `Gateways` > `General` > `Server Certificate`

Default Value:

Not configured

References:

1. https://www.paloaltonetworks.com/documentation/60/globalprotect/global_protect_6-0/set-up-the-globalprotect-infrastructure/globalprotect-certificate-best-practices
2. https://www.paloaltonetworks.com/documentation/60/globalprotect/global_protect_6-0/set-up-the-globalprotect-infrastructure/deploy-server-certificates-to-the-globalprotect-components

ARCHIVE

2 User Identification

The User Identification section covers requirements for IP address mapping and User-ID functionality.

2.1 Ensure that IP addresses are mapped to usernames (Scored)

Profile Applicability:

- Level 2

Description:

Configure appropriate settings to map IP addresses to usernames. Mapping userids to IP addresses is what permits the firewall to create rules based on userids and groups rather than IP addresses and subnets, as well as log events by userids rather than IP addresses or DNS names. The specifics of how to achieve IP-to-username mapping is highly dependent on the environment. It can be enabled by integrating the firewall with a domain controller, Exchange server, captive portal, Terminal Server, User-ID Agent, XML API, or syslog data from a variety of devices.

Rationale:

Understanding which user is involved in a security incident allows appropriate personnel to move quickly between the detection and reaction phases of incident response. In environments with either short DHCP lease times, or where users may move frequently between systems, the ability to analyze or report, or alert on events based on user accounts or user groups is a tremendous advantage. For forensics tasks when DHCP lease information may not be available, the Source User information may be the only way to tie together related data.

Audit:

To validate if this recommendation has been met, look at the `Source User` column in the URL Filtering or Traffic logs (`Monitor > Logs > URL Filtering` and `Monitor > Logs > Traffic Logs`, respectively.) User traffic originating from a trusted zone should identify a username.

or

Execute the following CLI command to display the status of the Agent and connection statistics:

ARCHIVE

```
username@hostname#show user user-id-agent state all
```

Execute the following CLI command to display IP mappings:

```
 username@hostname#show user ip-user-mapping all
```

Execute the following CLI command if using an LDAP server:

```
username@hostname#show user group-mapping state all
username@hostname#show user group list
username@hostname#show user group name <group name>
```

Remediation:

To Set User-ID Agents
Navigate to `Device` > `User-ID Agents`
Set the Name, IP Address and Port of the User-ID Agent

Enable User Identification for each monitored zone that will have user accounts:
Navigate to `Network` > `Zone`, for each relevant zone enable `User Identification`

To Set Terminal Services Agents
Navigate to `Device` > `Terminal Services Agents`
Set the Name, IP Address and Port of the Terminal Services Agent

Enable User Identification for each monitored zone that will have Terminal Servers:
Navigate to `Network` > `Zone`, enable `User Identification`

References:

1. "Best Practices for Securing User-ID Deployments" - https://live.paloaltonetworks.com/docs/DOC-7912
2. "User-ID Best Practices - PAN-OS 5.0, 6.0" - https://live.paloaltonetworks.com/docs/DOC-6591
3. "How to Configure Group Mapping settings?" - https://live.paloaltonetworks.com/docs/DOC-4994
4. "PAN-OS Administrator's Guide 6.1 (English)" - https://www.paloaltonetworks.com/documentation/61/pan-os/pan-os
5. https://paloaltonetworks.com/content/dam/paloaltonetworks-com/en_US/assets/pdf/tech-briefs/techbrief-user-id.pdf

ARCHIVE

2.2 Ensure that WMI probing is disabled (Scored)

Profile Applicability:

- Level 2

Description:

Disable WMI probing if it is not required for User-ID functionality in the environment.

Rationale:

By default, WMI probing requires a domain administrator account. A malicious user could capture the encrypted password hash for offline cracking or relayed authentication attacks. Relying on other forms of user identification, such as security log monitoring, mitigates this risk.

Audit:

Navigate to `Device > User Identification > User Mapping > Palo Alto Networks User ID Agent Setup`.

Verify that `Enable Probing` is not checked.

Remediation:

Navigate to `Device > User Identification > User Mapping > Palo Alto Networks User ID Agent Setup`.

Set `Enable Probing` so it is unchecked.

Impact:

While this removes the exposure of having the WMI user account password being compromised, it also reduces the effectiveness of user identification during operation of the firewall (applying rules and policies). This trade-off should be weighed carefully for all installations.

Default Value:

Not configured

ARCHIVE

References:

1. "R7-2014-16: Palo Alto Networks User-ID Credential Exposure" - http://bit.ly/1GcbmD4
2. "Best Practices for Securing User-ID Deployments" - https://live.paloaltonetworks.com/docs/DOC-7912
3. "User-ID Best Practices - PAN-OS 5.0, 6.0" - https://live.paloaltonetworks.com/docs/DOC-6591

ARCHIVE

2.3 Ensure that User-ID is only enabled for internal trusted interfaces (Scored)

Profile Applicability:

- Level 1

Description:

Only enable the User-ID option for interfaces that are both internal and trusted. There is rarely a legitimate need to allow WMI probing on an untrusted interface.

Rationale:

PAN released a customer advisory in October of 2014 warning of WMI probing on untrusted interfaces with User-ID enabled. This can result in theft of the password hash for the account used in WMI probing.

Audit:

Navigate to `Network > Network Profiles > Interface Management`.

Verify that `User-ID` is only enabled for interfaces that are both internal and trusted.

Remediation:

Navigate to `Network > Network Profiles > Interface Management`.

Set `User-ID` to be checked only for interfaces that are both internal and trusted; uncheck it for all other interfaces.

References:

1. "Customer advisory: Security Impact of User-ID Misconfiguration" - https://live.paloaltonetworks.com/docs/DOC-8125
2. "R7-2014-16: Palo Alto Networks User-ID Credential Exposure" - http://bit.ly/1GcbmD4
3. "Best Practices for Securing User-ID Deployments" - https://live.paloaltonetworks.com/docs/DOC-7912
4. "User-ID Best Practices - PAN-OS 5.0, 6.0" - https://live.paloaltonetworks.com/docs/DOC-6591

ARCHIVE

2.4 Ensure that 'Include/Exclude Networks' is used if User-ID is enabled (Scored)

Profile Applicability:

- Level 1

Description:

If User-ID is configured, use the Include/Exclude Networks section to limit the User-ID scope to operate only on trusted networks. There is rarely a legitimate need to allow WMI probing on an untrusted network.

Rationale:

The Include/Exclude Networks feature allow users to configure boundaries for the User-ID service. By using the feature to limit User-ID probing to only trusted internal networks, the risks of privileged information disclosure through sent probes can be reduced. Note that if an entry appears in the Include/Exclude Networks section, an implicit exclude-all-networks policy will take effect for all other networks.

Audit:

Navigate to `Device > User Identification > User Mapping > Include/Exclude Networks`.

Verify that all trusted internal networks have a Discovery value of `Include`.

Verify that all untrusted external networks have a Discovery value of `Exclude`.

Remediation:

Navigate to `Device > User Identification > User Mapping > Include/Exclude Networks`.

Set all trusted internal networks to have a Discovery value of `Include`.

Set all untrusted external networks to have a Discovery value of `Exclude`.

Default Value:

Not configured

ARCHIVE

References:

1. Best Practices for Securing User-ID Deployments - https://live.paloaltonetworks.com/docs/DOC-7912

ARCHIVE

2.5 Ensure that the User-ID Agent has minimal permissions if User-ID is enabled (Scored)

Profile Applicability:

- Level 1

Description:

If the integrated (on-device) User-ID Agent is utilized, the Active Directory account for the agent should only be a member of the Event Log Readers group, Distributed COM Users group, and Domain Users group. If the Windows User-ID agent is utilized, the Active Directory account for the agent should only be a member of the Event Log Readers group, Server Operators group, and Domain Users group.

Rationale:

As a principle of least privilege, user accounts should have only minimum necessary permissions. If an attacker compromises a User-ID service account with domain admin rights, the organization is at far greater risk than if the service account were only granted minimum rights.

Audit:

Navigate to `Active Directory Users and Computers`.

Verify that the service account for the User-ID agent is not a member of any groups other than Event Log Readers, Distributed COM Users, and Domain Users (for the integrated, on-device User-ID agent) or Event Log Readers, Server Operators, and Domain Users (for the Windows User-ID agent.)

Remediation:

Navigate to `Active Directory Users and Computers`.

Set the service account for the User-ID agent so that it is only a member of the Event Log Readers, Distributed COM Users, and Domain Users (for the integrated, on-device User-ID agent) or the Event Log Readers, Server Operators, and Domain Users groups (for the Windows User-ID agent.)

Default Value:

Not configured

ARCHIVE

References:

1. "Best Practices for Securing User-ID Deployments" - https://live.paloaltonetworks.com/docs/DOC-7912
2. "User-ID Best Practices - PAN-OS 5.0, 6.0" - https://live.paloaltonetworks.com/docs/DOC-6591
3. "Configure User Mapping Using the Windows User-ID Agent" - https://www.paloaltonetworks.com/documentation/61/pan-os/pan-os/user-id/configure-user-mapping-using-the-windows-user-id-agent
4. "Configure User Mapping Using the PAN-OS Integrated User-ID Agent" - https://www.paloaltonetworks.com/documentation/61/pan-os/pan-os/user-id/configure-user-mapping-using-the-pan-os-integrated-user-id-agent.html

ARCHIVE

2.6 Ensure that the User-ID service account does not have interactive logon rights (Scored)

Profile Applicability:

- Level 1

Description:

Restrict the User-ID service account from interactively logging on to systems in the Active Directory domain.

Rationale:

In the event of a compromised User-ID service account, restricting interactive logins forbids the attacker from utilizing services such as RDP against computers in the Active Directory domain of the organization. This reduces the impact of a User-ID service account compromise.

Audit:

Navigate to `Active Directory Group Policies`.

Verify that Group Policies restricts the interactive logon privilege for the User-ID service account.

or

Navigate to `Active Directory Managed Service Accounts`.

Verify that Managed Service Accounts restricts the interactive logon privilege for the User-ID service account.

Remediation:

Navigate to `Active Directory Group Policies.`

Set Group Policies to restrict the interactive logon privilege for the User-ID service account.

or

Navigate to `Active Directory Managed Service Accounts.`

ARCHIVE

Set Managed Service Accounts to restrict the interactive logon privilege for the User-ID service account.

Default Value:

Not configured

References:

1. "Best Practices for Securing User-ID Deployments" - https://live.paloaltonetworks.com/docs/DOC-7912

ARCHIVE

2.7 Ensure remote access capabilities for the User-ID service account are forbidden. (Not Scored)

Profile Applicability:

- Level 1

Description:

Restrict the User-ID service account's ability to gain remote access into the organization. This capability could be made available through a variety of technologies, such as VPN, Citrix GoToMyPC, or TeamViewer. Remote services that integrate authentication with the organization's Active Directory may unintentionally allow the User-ID service account to gain remote access.

Rationale:

In the event of a compromised User-ID service account, restricting the account's ability to remotely access resources within the organization's internal network reduces the impact of a service account compromise.

Audit:

Auditing is operating-system dependent. For instance, in Windows Active Directory, this account should not be included in any group that grants the account access to VPN or Wireless access. In addition, domain administrative accounts should not have remote desktop (RDP) access to all domain member workstations.

Remediation:

Remove this account from all groups that might grant remote access to the network, or to any network services or hosts. Remediation is operating-system dependent. For instance, in Windows Active Directory, this account should be removed from any group that grants the account access to VPN or Wireless access. In addition, domain administrative accounts by default have remote desktop (RDP) access to all domain member workstations - this should be explicitly denied for this account.

Default Value:

Not configured

ARCHIVE

References:

1. "Best Practices for Securing User-ID Deployments" - https://live.paloaltonetworks.com/docs/DOC-7912
2. https://community.rapid7.com/docs/DOC-2881

ARCHIVE

2.8 Ensure that security policies restrict User-ID Agent traffic from crossing into untrusted zones (Scored)

Profile Applicability:

- Level 1

Description:

Create security policies to deny Palo Alto User-ID traffic originating from the interface configured for the UID Agent service that are destined to any untrusted zone.

Rationale:

If User-ID and WMI probes are sent to untrusted zones, the risk of privileged information disclosure exists. The information disclosed can include the User-ID Agent service account name, domain name, and encrypted password hashes sent in User-ID and WMI probes. To prevent this exposure, msrpc traffic originating from the firewall to untrusted networks should be explicitly denied. This security policy should be in effect even for environments not currently using WMI probing to help guard against possible probe misconfigurations in the future.

This setting is a "fail safe" to prevent exposure of this information if any of the other WMI User control settings are misconfigured.

Audit:

Navigate to `Device > Services > Services Features > Service Route Configuration > Customize.`

Click on the protocol in use (`IPv4` and/or `IPv6`).

Click `UID Agent.`

Click on the address object for the UID Agent's IP address.

Verify `SOURCE/NAME` is set to '`Deny msrpc to untrusted`'.

Verify `SOURCE/ZONE` is set to '`INSIDE`'.

Verify `SOURCE/Address` is set to the Address object for the UID Agent.

Verify `DESTINATION/ZONE` is set to '`GUEST`' and '`OUTSIDE`'.

Verify `DESTINATION/Address` is set to '`any`'.

ARCHIVE

Verify `DESTINATION/Application` is set to '`msrpc`'.

Verify `DESTINATION/Service` is set to '`application-default`'.

Verify `DESTINATION/Action` is set to '`Block`' (red circle with diagonal line).

Remediation:

Navigate to `Device > Services > Services Features > Service Route Configuration > Customize.`

Click on the protocol in use (`IPv4` and/or `IPv6`).

Click `UID Agent.`

Click on the address object for the UID Agent's IP address.

Set `SOURCE/NAME` to '`Deny msrpc to untrusted`'.

Set `SOURCE/ZONE` to '`INSIDE`'.

Set `SOURCE/Address` to the Address object for the UID Agent.

Set `DESTINATION/ZONE` to '`GUEST`' and '`OUTSIDE`'.

Set `DESTINATION/Address` to '`any`'.

Set `DESTINATION/Application` to '`msrpc`'.

Set `DESTINATION/Service` to '`application-default`'.

Set `DESTINATION/Action` to '`Block`' (red circle with diagonal line).

References:

1. "Best Practices for Securing User-ID Deployments" - https://live.paloaltonetworks.com/docs/DOC-7912

ARCHIVE

3 High Availability

The High Availability section includes requirements for High Availability peer synchronization and monitoring.

3.1 Ensure a fully-synchronized High Availability peer is configured (Scored)

Profile Applicability:

- Level 1

Description:

Ensure a High Availability peer is fully synchronized and in a passive or active state.

Rationale:

To ensure availability of both the firewall and the resources it protects, a High Availability peer is required. In the event a single firewall fails, or when maintenance such as a software update is required, the HA peer can be used to automatically fail over session states and maintain overall availability

Audit:

Navigate to `Device` > `High Availability` > `General.`

Click `General.`
Click `Data Link (HA2).`
Verify the correct interface is selected.
Verify the `protocol (IPv4 or IPv6)` is selected.
Verify the correct Transport is selected.
Verify the `Enable Session Synchronization` box is checked.

Remediation:

Navigate to `Device` > `High Availability` > `General.`

Click `General.`
Click `Data Link (HA2).`
Select the correct interface .
Select the `protocol (IPv4 or IPv6).`

ARCHIVE

Select the correct Transport.
Set the `Enable Session Synchronization` box to be checked.

`Save Configuration.`

Default Value:

Not Configured

ARCHIVE

3.2 Ensure 'High Availability' requires Link Monitoring and/or Path Monitoring (Scored)

Profile Applicability:

- Level 1

Description:

Configure Link Monitoring and/or Path Monitoring under High Availability options. If Link Monitoring is utilized, all links critical to traffic flow should be monitored.

Rationale:

If Link or Path Monitoring is not enabled, the standby router will not automatically take over as active if a critical link fails on the active firewall. Services through the firewall could become unavailable as a result.

Audit:

To verify Link Monitoring from GUI:
Navigate to `Device > High Availability > Link and Path Monitoring`.
Click `Link Monitoring`.
Verify the correct interfaces are in the `Link Group` and `Group Failure Conditions`
Click `Link Monitoring`.
Verify Failure Condition is set to `Any`.

To verify Path Monitoring from GUI:
Navigate to `Device > High Availability > Link and Path Monitoring`.
Click `Path Monitoring`.
Verify `Option` is set correctly.
Verify `Name, IP Address`, `Failure Condition` is set correctly.
Verify `Failure Condition` is set to `Any`.
Verify `Default setting` is set to `'Any'`.

Remediation:

To set Link Monitoring from GUI:
Navigate to `Device > High Availability > Link and Path Monitoring`.
Click `Link Monitoring`.
Set the correct interfaces to the `Link Group` and `Group Failure Conditions`.

ARCHIVE

Click `Link Monitoring`.
Set Failure Condition to `Any`.

To set Path Monitoring from GUI:
Navigate to `Device > High Availability > Link and Path Monitoring`.
Click `Path Monitoring`.
Set `Option` correctly.
`Set Name, IP Address`, `Failure Condition` correctly.
Set `Failure Condition` to `Any`.
Set `Default setting` to `Any`.

Default Value:

Not Configured

ARCHIVE

3.3 Ensure 'Passive Link State' and 'Preemptive' are configured appropriately (Scored)

Profile Applicability:

- Level 1

Description:

Set the Passive Link State to auto, and uncheck the Preemptive option to disable it.

Rationale:

Simultaneously enabling the 'Preemptive' option and setting the 'Passive Link State' option to 'Shutdown' could cause a 'preemptive loop' if Link and Path Monitoring are both configured. This will negatively impact the availability of the firewall and network services, should a monitored failure occur.

Audit:

To ensure `Active/Passive Settings` are configured correctly:

Navigate to `Device > High Availability > Active/Passive Settings.`

Verify `Passive Link State` is set to `auto`.

To ensure `Election Settings` are configured correctly:

Navigate to `Device > High Availability > Election Settings.`

Verify `Preemptive` is disabled.

or

Execute the following CLI commands to verify the HA configuration:

```
username@hostname#show high-availability all
```

Remediation:

To set `Active/Passive Settings` correctly:

Navigate to `Device > High Availability > Active/Passive Settings.`

Set `Passive Link State` to `auto`.

ARCHIVE

To set `Election Settings` correctly:

Navigate to `Device > High Availability > Election Settings.`

Set `Preemptive` to be disabled.

or

To remediate these settings, execute the following CLI command:

```
username@hostname#set deviceconfig high-availability group  mode active-passive
passive-link-state
```

Default Value:

Not Configured

References:

1. "PAN-OS Administrator's Guide 6.1 (English)" - https://live.paloaltonetworks.com/docs/DOC-8246

ARCHIVE

4 Dynamic Updates

The Dynamic Updates section covers requirements for scheduled downloads for antivirus updates and for applications and threats updates.

4.1 Ensure 'Antivirus Update Schedule' is set to download and install updates hourly (Scored)

Profile Applicability:

- Level 1

Description:

Set Antivirus Update Schedule to download and install updates hourly.

Rationale:

New antivirus definitions may be released at any time. With an hourly update schedule, the firewall can ensure threats with new definitions are quickly mitigated. A daily update schedule could leave an organization vulnerable to a known virus for nearly 24 hours, in a worst-case scenario. Setting an appropriate threshold value reduces the risk of a bad definition file negatively affecting traffic.

Audit:

Navigate to `Device > Dynamic Updates > Antivirus Update Schedule`.

Verify that `Action` is set to `Download and Install`.

Verify that `Recurrence` is set to `Hourly`.

or

Execute the following CLI command to verify antivirus update information:

```
username@hostname#request anti-virus upgrade info
Version                Size          Released on Downloaded         Installed
******************************************************************************
Verify correct version   size  date  time   and if/not downloaded      yes
```

Remediation:

Navigate to `Device > Dynamic Updates > Antivirus Update Schedule`.

Set `Action` to `Download and Install`.

ARCHIVE

Set `Recurrence` to `Hourly`.

or

To remediate these settings, execute the following CLI commands:

```
username@hostname#set deviceconfig system update-schedule anti-virus recurring daily
at WX:YZ
username@hostname#set deviceconfig system update-schedule anti-virus recurring daily
action download-and-install
```

Default Value:

Not Configured

References:

1. "Tips for Managing Content Updates" - https://live.paloaltonetworks.com/docs/DOC-1578
2. "PAN-OS Administrator's Guide 6.1 (English)" - https://live.paloaltonetworks.com/docs/DOC-8246

ARCHIVE

4.2 Ensure 'Applications and Threats Update Schedule' is set to download and install updates daily (Scored)

Profile Applicability:

- Level 1

Description:

Set the Applications and Threats Update Schedule to download and install updates daily.

Rationale:

New Applications and Threats file versions may be released at any time. With a daily update schedule, the firewall can ensure threats with new signatures are quickly mitigated, and the latest application signatures are applied.

Audit:

Navigate to `Device > Dynamic Updates > Application and Threats Update Schedule`.

Verify that `Action` is set to `Download and Install`.

Verify that `Recurrence` is set to `Daily`.

or

Execute the following CLI command to verify the update schedule:

```
username@hostname#set deviceconfig system update-schedule ?
```

Remediation:

Navigate to `Device > Dynamic Updates > Application and Threats Update Schedule`.

Set `Action` to `Download and Install`.

Set `Recurrence` to `Daily`.

or

To remediate these settings, execute the following CLI commands:

```
#set deviceconfig system update-schedule threats recurring daily at WX:YZ
#set deviceconfig system update-schedule threats recurring daily action download-and-
install
```

ARCHIVE

Default Value:

Not Configured

References:

1. "Tips for Managing Content Updates" - https://live.paloaltonetworks.com/docs/DOC-1578
2. "PAN-OS Administrator's Guide 6.1 (English)" - https://live.paloaltonetworks.com/docs/DOC-8246

ARCHIVE

5 Wildfire

WildFire is a cloud-based virtual malware detection, analysis, and blocking service that is native to Palo Alto next generation firewalls. The service detects and blocks targeted and unknown malware, exploits, and outbound command and control activity by observing malicious behavior in real time, rather than using pre-existing signatures. Post-analysis, WildFire generates protections that are shared globally in about 15 minutes.

The WildFire section covers requirements related to WildFire file size upload limits, file blocking profiles, decrypted content forwarding, session information settings, malicious file alerts, and update downloads.

5.1 Ensure that WildFire file size upload limits are maximized (Scored)

Profile Applicability:

- Level 1

Description:

Increase WildFire file size limits to the maximum file size supported by the environment. An organization with bandwidth constraints or heavy usage of unique files under a supported file type may require lower settings.

Rationale:

Increasing file size limits allows the devices to forward more files for WildFire analysis. This increases the chances of identifying, and later preventing, threats in larger files.

Audit:

Navigate to `Device > Setup > WildFire`.

Click the `General Settings` edit icon.

Verify the maximum size for each file type.

or

Execute the following CLI command to verify that the WildFire file size limits are set correctly:

```
username@hostname#run show wildfire status
```

ARCHIVE

Remediation:

Navigate to `Device > Setup > WildFire`.

Click the `General Settings` edit icon.

Set the maximum size for each file type.

Default Value:

Not Configured

References:

1. "WildFire Administrator's Guide 6.1 (English)" - https://live.paloaltonetworks.com/docs/DOC-8251
2. "How to Configure WildFire" - https://live.paloaltonetworks.com/docs/DOC-3252

ARCHIVE

5.2 Ensure forwarding is enabled for all applications and file types in WildFire file blocking profiles (Scored)

Profile Applicability:

- Level 1

Description:

Set Applications and File Types fields to any in WildFire file blocking profiles. With a WildFire license, seven file types are supported, while only PE (Portable Executable) files are supported without a license.

Rationale:

Selecting 'Any' application and file type ensures WildFire is analyzing as many files as possible.

Audit:

Navigate to `Objects > Security Profiles > File Blocking`.

Verify an appropriate rule exists with `Applications` set to `any`, `File Type` set to `any`, and `Action` set to `forward`.

Remediation:

Navigate to `Objects > Security Profiles > File Blocking`.

Set a rule so that `Applications` is set to `any`, `File Type` is set to `any`, and `Action` is set to `forward`.

or

From the CLI:

```
# set profiles file-blocking "How to configure File Blocking" rules "File Blocking"
action forward direction both application any file-type any
```

Default Value:

Not Configured

ARCHIVE

References:

1. "WildFire Administrator's Guide 6.1 (English)" - https://live.paloaltonetworks.com/docs/DOC-8251
2. "How to Configure WildFire" - https://live.paloaltonetworks.com/docs/DOC-3252
3. https://live.paloaltonetworks.com/docs/DOC-8706

ARCHIVE

5.3 Ensure a WildFire file blocking profile is enabled for all security policies allowing Internet traffic flows (Scored)

Profile Applicability:

- Level 1

Description:

Apply a WildFire file blocking profile to all security policies allowing Internet traffic flows. In the following example, the "WildFire" blocking profile is included in the "Inside to Outside" profile group.

Rationale:

Traffic matching security policies that do not include a WildFire file blocking profile will not utilize WildFire for file analysis. Wildfire analysis is one of the key security measures available on this platform. Without Wildfire analysis enabled, inbound malware can only be analyzed by signature - which industrywide is roughly 40-60% effective. In a targeted attack, the success of signature-based-only analysis drops even further.

Audit:

To verify File Blocking Profile
Navigate to Objects > Security Profiles > File Blocking > File Blocking Profile

To verify File Blocking Rules
Navigate to Policies > Security > Security Policy Rule > Actions > Profile Setting > File Blocking.

Verify a WildFire file blocking profile exists with `Source Zone INSIDE`, `Address any`, and `User any`; with `Destination Zone OUTSIDE`, `Address any`, `Service any`, and `Application` set to all denied applications; and with `Action` set to `Deny`.

Verify a WildFire file blocking profile exists with `Source Zone INSIDE`, `Address any`, and `User any`; with `Destination Zone OUTSIDE`, `Address any`, `Application any`, and `Service` set to all denied service ports; and with `Action` set to `Deny`.

ARCHIVE

Remediation:

To Set File Blocking Profile
Navigate to Objects > Security Profiles > File Blocking > File Blocking Profile

To Set File Blocking Rules
Navigate to Policies > Security > Security Policy Rule > Actions > Profile Setting > File Blocking.

Set a WildFire file blocking profile with `Source Zone INSIDE`, `Address any`, and `User any`; with `Destination Zone OUTSIDE`, `Address any`, `Service any`, and `Application` set to all denied applications; and with `Action` set to `Deny`.

Set a WildFire file blocking profile with `Source Zone INSIDE`, `Address any`, and `User any`; with `Destination Zone OUTSIDE`, `Address any`, `Application any`, and `Service` set to all denied service ports; and with `Action` set to `Deny`.

Default Value:

Not Configured

References:

1. "WildFire Administrator's Guide 6.1 (English)" - https://live.paloaltonetworks.com/docs/DOC-8251

ARCHIVE

5.4 Ensure forwarding of decrypted content to WildFire is enabled (Scored)

Profile Applicability:

- Level 1

Description:

Allow the firewall to forward decrypted content to WildFire. Note that SSL Forward-Proxy must also be enabled and configured for this setting to take effect on inside-to-outside traffic flows.

Rationale:

As encrypted Internet traffic continues to proliferate, WildFire becomes less effective unless it is allowed to act on decrypted content. For example, if a user downloads a malicious pdf over SSL, WildFire can only provide analysis if 1) the session is decrypted by the firewall and 2) forwarding of decrypted content is enabled. In today's internet, roughly 70-80% of all user traffic is encrypted. If Wildfire is not configured to analyze encrypted content, the effectiveness of Wildfire is drastically reduced.

Audit:

Navigate to `Device > Setup > Content-ID > Content-ID Settings`.

Verify that `Allow forwarding of decrypted content` is checked.

or

Execute the following CLI command to verify ssl-decryption configuration:

```
username@hostname#show setting ssl-decrypt | match decrypted
```

Remediation:

Navigate to `Device > Setup > Content-ID > Content-ID Settings`.

Set `Allow forwarding of decrypted content` to be checked.

or

Execute the following CLI command to set the ssl-decryption configuration:

ARCHIVE

```
username@hostname#configure
username@hostname#set setting ssl-decrypt allow-forward-decrypted-content yes
username@hostname#commit
```

Default Value:

Not Configured

References:

1. "WildFire Fails Forwarding File to Cloud for Encrypted Traffic" - https://live.paloaltonetworks.com/docs/DOC-6845
2. "WildFire Administrator's Guide 6.1 (English)" - https://live.paloaltonetworks.com/docs/DOC-8251

ARCHIVE

5.5 Ensure all WildFire session information settings are enabled (Scored)

Profile Applicability:

- Level 1

Description:

Enable all options under Session Information Settings for WildFire.

Rationale:

Permitting the firewall to send all of this information to WildFire creates more detailed reports, thereby making the process of tracking down potentially infected devices more efficient. This could prevent an infected system from further infecting the environment. Environments with security policies restricting sending this data to the WildFire cloud can instead utilize an on-premises WildFire appliance. In addition, risk can be analyzed in the context of the destination host and user account, either during analysis or during incident response.

Audit:

Navigate to `Device > Setup > WildFire > Session Information Settings`.

Verify that every option is enabled.

Remediation:

Navigate to `Device > Setup > WildFire > Session Information Settings`.

Set every option to be enabled.

Default Value:

Not Configured

References:

1. "WildFire Administrator's Guide 6.1 (English)" - https://live.paloaltonetworks.com/docs/DOC-8251

ARCHIVE

5.6 Ensure alerts are enabled for malicious files detected by WildFire (Scored)

Profile Applicability:

- Level 1

Description:

Configure WildFire to send an alert when a malicious file is detected. This alert could be sent by whichever means is preferable, including email, SNMP trap, or syslog message.

Alternatively, configure the WildFire cloud to generate alerts for malicious files. The cloud can generate alerts in addition to or instead of the local WildFire implementation. Note that the destination email address of alerts configured in the WildFire cloud portal is tied to the logged in account, and cannot be modified. Also, new systems added to the WildFire cloud portal will not be automatically set to email alerts.

Rationale:

WildFire analyzes files that have already been downloaded and possibly executed. A WildFire verdict of malicious indicates that a computer could already be infected. In addition, because WildFire only analyzes files it has not already seen that were not flagged by the firewall's antivirus filter, files deemed malicious by WildFire are more likely to evade detection by desktop antivirus products.

Audit:

Navigate to `Objects > Log Forwarding`.

Verify that the `WildFire` log type is configured to generate alerts using the desired alerting mechanism.

Remediation:

From GUI:
Navigate to `Device` > `Server Profiles` > `Email`
Click `Add`
Enter a name for the Profile
Select the virtual system from the Location drop down menu (if applicable)
Click `Add`

ARCHIVE

Configure the Syslog Server:
`Name, Display Name, Syslog Server, Transport, Port, Format, Facility`
Click `OK`
Click `Commit` to save the configuration

Configure the SMTP Server:
`Name, Display Name, From, To, Additional Recipients, Gateway IP or Hostname`
Click `OK`
Click `Commit` to save the configuration

Default Value:

Not Configured

References:

1. "WildFire Email Alerts: Subscribe or Add Additional Recipients" - https://live.paloaltonetworks.com/docs/DOC-7740
2. "WildFire Administrator's Guide 6.1 (English)" - https://live.paloaltonetworks.com/docs/DOC-8251

ARCHIVE

5.7 Ensure 'WildFire Update Schedule' is set to download and install updates every 15 minutes (Scored)

Profile Applicability:

- Level 1

Description:

Set the WildFire update schedule to download and install updates every 15 minutes.

Rationale:

WildFire definitions may contain signatures to block immediate, active threats to the environment. With a 15 minute update schedule, the firewall can ensure threats with new definitions are quickly mitigated.

Audit:

Navigate to `Device > Dynamic Updates > WildFire Update Schedule`.

Verify that `Action` is set to `Download and Install`.

Verify that `Recurrence` is set to `Every 15 Minutes`.

or

Execute the following CLI command to verify the update-schedule is configured:

```
username@hostname#set deviceconfig system update-schedule ?
```

Remediation:

Navigate to `Device > Dynamic Updates > WildFire Update Schedule`.

Set `Action` to `Download and Install`.

Set `Recurrence` to `Every 15 Minutes`.

or

Execute the following CLI command to set the update schedule:

```
username@hostname#set deviceconfig system update-schedule wildfire recurring every-15-
mins action download-and-install
```

ARCHIVE

Default Value:

Not Configured

References:

1. "WildFire Administrator's Guide 6.1 (English)" - https://live.paloaltonetworks.com/docs/DOC-8251
2. "How to Configure WildFire" - https://live.paloaltonetworks.com/docs/DOC-3252
3. "Tips for Managing Content Updates" - https://live.paloaltonetworks.com/docs/DOC-1578
4. "PAN-OS Administrator's Guide 6.1 (English)" - https://live.paloaltonetworks.com/docs/DOC-8246

ARCHIVE

6 Security Profiles

The Security Profiles section covers requirements for several types of profiles, including antivirus, anti-spyware, Vulnerability Protection Profiles, URL filtering, URL logging, data filtering, and Zone Protection Profiles.

6.1 Ensure at least one antivirus profile is set to block on all decoders except 'imap' and 'pop3' (Scored)

Profile Applicability:

- Level 1

Description:

Configure at least one antivirus profile to a value of 'block' for all decoders except imap and pop3 under both Action and WildFire Action. Configure imap and pop3 decoders to 'alert' under both Action and WildFire Action.

Rationale:

Antivirus signatures produce low false positives. By blocking any detected malware through the specified decoders, the threat of malware propagation through the firewall is greatly reduced. It is recommended to mitigate malware found in pop3 and imap through a dedicated antivirus gateway. Due to the nature of the pop3 and imap protocols, the firewall is not able to block only a single email message containing malware. Instead, the entire session would be terminated, potentially affecting benign email messages.

Audit:

Navigate to `Objects` > `Security Profiles` > `Antivirus`

Verify that at least one antivirus profile has all decoders except `imap` and `pop3` set to `block` for both `Action` and `Wildfire Action`, and that the `imap` and `pop3` decoders are set to `alert` for both `Action` and `Wildfire Action`.

Remediation:

Navigate to `Objects` > `Security Profiles` > `Antivirus`.

Set at least one antivirus profile to have all decoders except `imap` and `pop3` set to `block` for both `Action` and `Wildfire Action`, and the `imap` and `pop3` decoders set to `alert` for both `Action` and `Wildfire Action`.

ARCHIVE

Default Value:

Not Configured

References:

1. "Threat Prevention Deployment Tech Note" - https://live.paloaltonetworks.com/docs/DOC-3094

ARCHIVE

6.2 Ensure a secure antivirus profile is applied to all relevant security policies (Scored)

Profile Applicability:

- Level 1

Description:

Create a secure antivirus profile and apply it to all security policies that could pass HTTP, SMTP, IMAP, POP3, FTP, or SMB traffic. The antivirus profile may be applied to the security policies directly or through a profile group.

Rationale:

By applying a secure antivirus profile to all applicable traffic, the threat of malware propagation through the firewall is greatly reduced. Without an antivirus profile assigned to any potential hostile zone, the first protection in the path against malware is removed, leaving in most cases only the desktop endpoint protection application to detect and remediate any potential malware.

Audit:

Navigate to `Objects` > `Security Profiles` > `Antivirus Policies` > `Security`

Verify there is an `Antivirus profile` applied to all security policies passing traffic - regardless of protocol.
Verify each Decoder contains `Action` set to Block and `Wildfire Action` set to Block
Verify the `Source Zone` is INSIDE and `Source Address` is ANY
Verify the `Destination Zone` is OUTSIDE and `Destination Address` is ANY
Verify `Application` is ANY
Verify `Service` is ANY
Verify `Action` is checked
Verify `Profile` is BlockAll-AV

Remediation:

Navigate to `Objects` > `Security Profiles` > `Antivirus Policies` > `Security`
Set an `Antivirus profile` for all security policies passing traffic - regardless of protocol.
Ensure each Decoder contains `Action` set to Block and `Wildfire Action` set to Block
Set the `Source Zone` to INSIDE and `Source Address` to ANY
Set the `Destination Zone` to OUTSIDE and `Destination Address` to ANY

ARCHIVE

Set `Application` to ANY
Set `Service` to ANY
Set `Action` to checked
Set `Profile` to BlockAll-AV

ARCHIVE

6.3 Ensure an anti-spyware profile is configured to block on all spyware severity levels, categories, and threats (Scored)

Profile Applicability:

- Level 1

Description:

If a single rule exists within the anti-spyware profile, configure it to block on any spyware severity level, any category, and any threat. If multiple rules exist within the anti-spyware profile, ensure all spyware categories, threats, and severity levels are set to be blocked. Additional rules may exist for packet capture or exclusion purposes.

Rationale:

Requiring a blocking policy for all spyware threats, categories, and severities reduces the risk of spyware traffic from successfully exiting the organization. Without an anti-spyware profile assigned to any potential hostile zone, the first protection in the path against malware is removed, leaving in most cases only the desktop endpoint protection application to detect and remediate any potential spyware.

Audit:

Navigate to `Objects` > `Security Profiles` > `Anti-Spyware`

Verify a rule exists within the anti-spyware profile that is configured to perform the `Block Action` on `any Severity` level, `any Category`, and `any Threat Name`.

Remediation:

Navigate to `Objects` > `Security Profiles` > `Anti-Spyware`

Set a rule within the anti-spyware profile that is configured to perform the `Block Action` on `any Severity` level, `any Category`, and `any Threat Name`.

Default Value:

Not Configured

References:

1. "Threat Prevention Deployment Tech Note" - https://live.paloaltonetworks.com/docs/DOC-3094

ARCHIVE

6.4 Ensure DNS sinkholing is configured on all anti-spyware profiles in use (Scored)

Profile Applicability:

- Level 1

Description:

Configure DNS sinkholing for all anti-spyware profiles in use. All internal requests to the selected sinkhole IP address must traverse the firewall. Any device attempting to communicate with the DNS sinkhole IP address should be considered infected.

Rationale:

DNS sinkholing helps to identify infected clients by spoofing DNS responses for malware domain queries. Without sinkholing, the DNS server itself may be seen as infected, while the truly infected device remains unidentified. In addition, sinkholing also ensures that DNS queries that might be indicators of compromise do not transit the internet, where they could be potentially used to negatively impact the "ip reputation" of the organization's internet network subnets.

Audit:

Navigate to `Objects` > `Security Profiles` > `Anti-Spyware`

Within the anti-spyware profile, under its `DNS Signatures` tab, verify that `Action on DNS queries` is set to `sinkhole`.

Verify the '`Sinkhole IPv4`' IP address is correct.

Verify the '`Sinkhole IPv6`' IP address is correct.

Remediation:

Navigate to `Objects` > `Security Profiles` > `Anti-Spyware`

Within the anti-spyware profile, under its `DNS Signatures` tab, set `Action on DNS queries` to `sinkhole`.

Set '`Sinkhole IPv4`' to the correct IP address.

Set '`Sinkhole IPv6`' to the correct IP address.

ARCHIVE

Default Value:

Not Configured

References:

1. "How to Deal with Conficker using DNS Sinkhole" - https://live.paloaltonetworks.com/docs/DOC-6628
2. "Threat Prevention Deployment Tech Note" - https://live.paloaltonetworks.com/docs/DOC-3094
3. "PAN-OS Administrator's Guide 6.1 (English)" - https://live.paloaltonetworks.com/docs/DOC-8246

ARCHIVE

6.5 Ensure passive DNS monitoring is set to enabled on all anti-spyware profiles in use (Scored)

Profile Applicability:

- Level 1

Description:

Enable passive DNS monitoring within all anti-spyware profiles in use.

Rationale:

Enabling passive DNS monitoring improves PAN's threat prevention and threat intelligence capabilities. This is performed without source information delivered to PAN to ensure sensitive DNS information of the organization is not compromised.

Audit:

Navigate to `Objects` > `Security Profiles` > `Anti-Spyware` > `Policies` > `Security`.

For each anti-spyware profile in use, verify the `Enable Passive DNS Monitoring` box is checked under the `DNS Signatures` tab.

Remediation:

Navigate to `Objects > Security Profiles > Anti-Spyware Policies > Security`.

For each anti-spyware profile in use, set the `Enable Passive DNS Monitoring` box under the `DNS Signatures` tab to be checked.

Default Value:

Not Configured

References:

1. "What Information is Submitted to the Palo Alto Networks when Enabling the Passive DNS Feature" - https://live.paloaltonetworks.com/docs/DOC-7256
2. "PAN-OS Administrator's Guide 6.1 (English)" - https://live.paloaltonetworks.com/docs/DOC-8246

ARCHIVE

6.6 Ensure a secure anti-spyware profile is applied to all security policies permitting traffic to the Internet (Scored)

Profile Applicability:

- Level 1

Description:

Create one or more anti-spyware profiles and collectively apply them to all security policies permitting traffic to the Internet. The anti-spyware profiles may be applied to the security policies directly or through a profile group.

Rationale:

By applying secure anti-spyware profiles to all applicable traffic, the threat of sensitive data exfiltration or command-and-control traffic successfully passing through the firewall is greatly reduced. Anti-spyware profiles are not restricted to particular protocols like antivirus profiles, so anti-spyware profiles should be applied to all security policies permitting traffic to the Internet. Assigning an anti-spyware profile to each trusted zone will quickly and easily identify trusted hosts that have been infected with spyware, by identifying the infection from their outbound network traffic. In addition, that outbound network traffic will be blocked by the profile.

Audit:

Navigate to `Objects` > `Security Profiles` > `Anti-Spyware`.

Also navigate to `Policies > Security`.

Verify there are one or more anti-spyware profiles that collectively apply to all inside to outside traffic from any address to any address and any application and service.

Remediation:

Navigate to `Objects` > `Security Profiles` > `Anti-Spyware`.

Also navigate to `Policies > Security`.

Set one or more anti-spyware profiles to collectively apply to all inside to outside traffic from any address to any address and any application and service.

ARCHIVE

Default Value:

Not Configured

References:

1. "Threat Prevention Deployment Tech Note" - https://live.paloaltonetworks.com/docs/DOC-3094

ARCHIVE

6.7 Ensure a Vulnerability Protection Profile is set to block attacks against critical and high vulnerabilities, and set to default on medium, low, and informational vulnerabilities (Scored)

Profile Applicability:

- Level 1

Description:

Configure a Vulnerability Protection Profile set to block attacks against any critical or high vulnerabilities, at minimum, and set to default on any medium, low, or informational vulnerabilities. Configuring an alert action for low and informational, instead of default, will produce additional information at the expense of greater log utilization.

Rationale:

A Vulnerability Protection Profile helps to protect assets by alerting on, or blocking, network attacks. The default action for attacks against many critical and high vulnerabilities is to only alert on the attack - not to block.

Audit:

Navigate to `Objects` > `Security Profiles` > `Vulnerability Protection.`

Verify a Vulnerability Protection Profile is set to block attacks against any critical or high vulnerabilities (minimum), and set to default on attacks against any medium, low, or informational vulnerabilities.

Remediation:

Navigate to `Objects > Security Profiles > Vulnerability Protection.`

Set a Vulnerability Protection Profile to block attacks against any critical or high vulnerabilities (minimum), and to default on attacks against any medium, low, or informational vulnerabilities.

References:

1. "Threat Prevention Deployment Tech Note" - https://live.paloaltonetworks.com/docs/DOC-3094
2. "PAN-OS Administrator's Guide 6.1 (English)" - https://live.paloaltonetworks.com/docs/DOC-8246

ARCHIVE

6.8 Ensure a secure Vulnerability Protection Profile is applied to all security rules allowing traffic (Scored)

Profile Applicability:

- Level 1

Description:

For any security rule allowing traffic, apply a securely configured Vulnerability Protection Profile. Careful analysis of the target environment should be performed before implementing this configuration, as outlined by PAN's "Threat Prevention Deployment Tech Note" in the references section.

Rationale:

A Vulnerability Protection Profile helps to protect assets by alerting on, or blocking network attacks. By applying a secure Vulnerability Protection Profile to all security rules permitting traffic, all network traffic traversing the firewall will be inspected for attacks. This protects both organizational assets from attack and organizational reputation from damage.

Note that encrypted sessions do not allow for complete inspection.

Audit:

Navigate to `Policies > Security`.

Under the `Actions` tab, select `Vulnerability Protection`.

Verify either the 'Strict' or the 'Default' profile is selected.

Remediation:

Navigate to `Policies > Security`.

Under the `Actions` tab, select `Vulnerability Protection`.

Set it to use either the 'Strict' or the 'Default' profile.

Default Value:

Not Configured

ARCHIVE

References:

1. "Threat Prevention Deployment Tech Note" - https://live.paloaltonetworks.com/docs/DOC-3094
2. "PAN-OS Administrator's Guide 6.1 (English)" - https://live.paloaltonetworks.com/docs/DOC-8246

ARCHIVE

6.9 Ensure that PAN-DB URL Filtering is used (Scored)

Profile Applicability:

- Level 1

Description:

Configure the device to use PAN-DB URL Filtering instead of BrightCloud.

Rationale:

Standard URL filtering provides protection against inappropriate and malicious URLs and IP addresses. PAN-DB URL Filtering offers additional malware protection and PAN threat intelligence that is currently not available in the BrightCloud URL Filtering license.

Audit:

Navigate to `Device > Licenses`.

Click on `PAN-DB URL Filtering`.

Verify `Active` is set to `Yes`.

or

To display current URL Filtering DB version #:

```
> show system info
```

To display URL database:

```
> show system setting url-database
```

To display URL Filtering feature settings:

```
> show system setting url-filtering-feature
```

To display the cloud status:

```
> show url-cloud status
```

Remediation:

Navigate to `Device > Licenses`.

Click on `PAN-DB URL Filtering`.

ARCHIVE

Set `Active` to `Yes`.

Default Value:

Not Configured

ARCHIVE

6.10 Ensure that URL Filtering uses the action of "block" or "override" on the URL categories (Scored)

Profile Applicability:

- Level 1

Description:

Ideally, deciding which URL categories to block, and which to allow, is a joint effort between IT and another entity of authority within an organization—such as the legal department or administration. For most organizations, blocking or requiring an override on the following categories represents a minimum baseline: adult, hacking, malware, phishing, and proxy-avoidance-and-anonymizers.

Rationale:

Certain URL categories pose a technology-centric threat, such as malware, phishing, hacking, and proxy-avoidance-and-anonymizers. Users visiting websites in these categories, many times unintentionally, are at greater risk of compromising the security of their system. Other categories, such as adult, may pose a legal liability.

Audit:

Navigate to `Objects > Security Profiles > URL Filtering`.

Verify that all URL categories designated by the organization are listed in `Block Categories` or `Override Categories`.

Remediation:

Navigate to `Objects > Security Profiles > URL Filtering`.

Set a URL filter so that all URL categories designated by the organization are listed in `Block Categories` or `Override Categories`.

Default Value:

Not Configured

References:

1. "PAN-OS Administrator's Guide 6.1 (English)" - https://live.paloaltonetworks.com/docs/DOC-8246

ARCHIVE

6.11 Ensure that access to every URL is logged (Scored)

Profile Applicability:

- Level 1

Description:

URL filters should not specify any categories as `Allow Categories`.

Rationale:

Setting a URL filter to have one or more entries under Allow Categories will cause no log entries to be produced in the URL Filtering logs for access to URLs in those categories. For forensic, legal, and HR purposes, it is advisable to log access to every URL. In many cases failure to log all URL access is a violation of corporate policy, legal requirements or regulatory requirements.

Audit:

Navigate to `Objects > Security Profiles > URL Filtering`.

Verify that the `Allow Categories` column is blank.

Remediation:

Navigate to `Objects > Security Profiles > URL Filtering`.

Set the `Allow Categories` column so that it is blank.

Default Value:

Not Configured

References:

1. "PAN-OS Administrator's Guide 6.1 (English)" - https://live.paloaltonetworks.com/docs/DOC-8246

ARCHIVE

6.12 Ensure all HTTP Header Logging options are enabled (Scored)

Profile Applicability:

- Level 1

Description:

Enable all options (User-Agent, Referer, and X-Forwarded-For) for HTTP header logging.

Rationale:

Logging HTTP header information provides additional information in the URL logs, which may be useful during forensic investigations. The User-Agent option logs which browser was used during the web session, which could provide insight to the vector used for malware retrieval. The Referer option logs the source webpage responsible for referring the user to the logged webpage. The X-Forwarded-For option is useful for preserving the user's source IP address, such as if a user traverses a proxy server prior to the firewall. Un-checking the Log container page only box produces substantially more information about web activity, with the expense of producing far more entries in the URL logs. If this option remains checked, a URL filter log entry showing details of a malicious file download may not exist.

Audit:

Navigate to `Objects > Security Profiles > URL Filtering > URL Filtering Profile > Settings`.

Verify these four settings:

a. `Log container page only` box is un-checked

b. `User-Agent` box is checked

c. `Referer` box is checked

d. `X-Forwarded-For` box is checked

Remediation:

Navigate to `Objects > Security Profiles > URL Filtering > URL Filtering Profile > Settings`.

Set the following four settings:

ARCHIVE

a. `Log container page only` box is un-checked

b. Check the `User-Agent` box

c. Check the `Referer` box

d. Check the `X-Forwarded-For` box

Default Value:

Not Configured

References:

1. "PAN-OS Administrator's Guide 6.1 (English)" - https://live.paloaltonetworks.com/docs/DOC-8246

ARCHIVE

6.13 Ensure secure URL filtering is enabled for all security policies allowing traffic to the Internet (Scored)

Profile Applicability:

- Level 1

Description:

Apply a secure URL filtering profile to all security policies permitting traffic to the Internet. The URL Filtering profile may be applied to the security policies directly or through a profile group.

Rationale:

URL Filtering policies dramatically reduce the risk of users visiting malicious or inappropriate websites. In addition, a complete URL history log for all devices is invaluable when performing forensic analysis in the event of a security incident. Applying complete and approved URL filtering to outbound traffic is a frequent requirement in corporate policies, legal requirements or regulatory requirements.

Audit:

To Verify URL Filtering

Navigate to `Policies` > `Security` > `Security Profiles` > `URL Filtering`
Navigate to `Objects` > `Security Profiles` > `URL Filtering`

Verify there is a URL Filtering profile applied to:

SOURCE: Name: Inside to Outside Zone: INSIDE Address: Any
DESTINATION: Zone: OUTSIDE Address: ANY Application: ANY Service: ANY

Remediation:

To Set URL Filtering

Navigate to `Policies` > `Security` > `Security Profiles` > `URL Filtering`
Navigate to `Objects` > `Security Profiles` > `URL Filtering`

Ensure there is a URL Filtering profile set to:

SOURCE: Name: Inside to Outside Zone: INSIDE Address: Any
DESTINATION: Zone: OUTSIDE Address: ANY Application: ANY Service: ANY

ARCHIVE

Default Value:

Not Configured

References:

1. "PAN-OS Administrator's Guide 6.1 (English)" - https://live.paloaltonetworks.com/docs/DOC-8246

ARCHIVE

6.14 Ensure alerting after a threshold of credit card or Social Security numbers is detected is enabled (Scored)

Profile Applicability:

- Level 1

Description:

This guideline is highly specific to an organization. While blocking of credit card or Social Security numbers will not occur with the recommended settings below, careful tuning is also recommended.

Configure a Data Pattern with the following values:

CC# - 10

SSN# - 20

SSN# (without dash) – 1

Rationale:

Credit card and Social Security numbers are sensitive, and should never traverse an organization's Internet connection in clear text. Passing sensitive data within an organization should also be avoided whenever possible. Detecting and blocking known sensitive information is a basic protection against a data breach or data loss. Not implementing these defenses can lead to loss of regulatory accreditation (such as PCI, HIPAA etc), or can lead to legal action from injured parties or regulatory bodies.

Audit:

From GUI:
Navigate to `Objects` > `Security Profiles` > `Data Patterns`
Verify an appropriate Data Pattern has been created with CC# set to `10`, SSN# set to `20`, and SSN# (without dash) set to `1`.

Navigate to `Objects` > `Security Profiles` > `Data Filtering`
Verify an appropriate Data Filtering Profile has been created:
Data Pattern: `CC-and-SS-Weight`
Applications: `ANY`
File Types: `ANY`
Direction: `Both`

ARCHIVE

Alert Threshold: `20`
Block Threshold: `0`

Remediation:

From GUI:
Navigate to `Objects` > `Security Profiles` > `Data Patterns`
Create an appropriate Data Pattern with CC# set to `10`, SSN# set to `20`, and SSN# (without dash) set to `1`.

Navigate to `Objects` > `Security Profiles` > `Data Filtering`
Create an appropriate Data Filtering Profile:
Data Pattern: `CC-and-SS-Weight`
Applications: `ANY`
File Types: `ANY`
Direction: `Both`
Alert Threshold: `20`
Block Threshold: `0`

Default Value:

Not Configured

References:

1. "What are the Data Filtering Best Practices?" - https://live.paloaltonetworks.com/docs/DOC-2513
2. "PAN-OS Administrator's Guide 6.1 (English)" - https://live.paloaltonetworks.com/docs/DOC-8246

ARCHIVE

6.15 Ensure a secure Data Filtering profile is applied to all security policies allowing traffic to or from the Internet (Scored)

Profile Applicability:

- Level 1

Description:

Create a secure Data Filtering profile and apply it to all security policies permitting traffic to or from the Internet. The Data Filtering profile may be applied to security policies directly or through a profile group.

Rationale:

A Data Filtering profile helps prevent certain types of sensitive information from traversing an organization's Internet connection in clear text. Detecting and blocking known sensitive information is a basic protection against a data breach or data loss. Not implementing these defenses can lead to loss of regulatory accreditation (such as PCI, HIPAA etc), or can lead to legal action from injured parties or regulatory bodies.

Audit:

From GUI:
Navigate to `Objects` > `Security Profiles` > `Data Filtering`
Verify a Data Filtering Profile exists:
Applies to all security policies allowing traffic from Internet
The Shared and Data Capture boxes are checked
Data Pattern is `CC-and-SS-Weight`
Applications are `Any`
File Types are `Any`
Direction is `Both`
Alert Threshold is `20`
Block Threshold is `0`

Verify a Data Threshold Profile is applied to all Security Policies permitting traffic to the Internet.

Remediation:

From GUI:
Navigate to `Objects` > `Security Profiles` > `Data Filtering`

ARCHIVE

Create a Data Filtering Profile:
Applies to all security policies allowing traffic from Internet
`Check` the Shared and Data Capture boxes
Data Pattern set to `CC-and-SS-Weight`
Applications set to `Any`
File Types set to `Any`
Direction set to `Both`
Alert Threshold set to `20`
Block Threshold set to `0`

Configure a Data Threshold Profile to be applied to all Security Policies permitting traffic to the Internet.

Default Value:

Not Configured

References:

1. "PAN-OS Administrator's Guide 6.1 (English)" - https://live.paloaltonetworks.com/docs/DOC-8246

ARCHIVE

6.16 Ensure that a Zone Protection Profile with an enabled SYN Flood Action of SYN Cookies is attached to all untrusted zones (Scored)

Profile Applicability:

- Level 1

Description:

Enable the SYN Flood Action of SYN Cookies for all untrusted zones. The Alert, Activate, and Maximum settings for SYN Flood Protection depend highly on the environment and device used. Perform traffic analysis on the specific environment and firewall to determine accurate thresholds. Do not rely on default values to be appropriate for an environment.

As a rough ballpark for most environments, an Activate value of 50% of the firewall's maximum "New sessions per second"/CPS is a conservative setting. The following is a list of new sessions per second maximum for each platform:

PA-200 = 1,000 CPS

PA-500 = 7,500 CPS

PA-2000 series = 15,000 CPS

PA-3000 series = 50,000 CPS

PA-5000 series = 120,000 CPS

PA-7050 = 720,000 CPS

Rationale:

Protecting resources and the firewall itself against DoS/DDoS attacks requires a layered approach. Firewalls alone cannot mitigate all DoS attacks, however, many attacks can be successfully mitigated. Utilizing SYN Cookies helps to mitigate SYN flood attacks, where the CPU and/or memory buffers of the victim device become overwhelmed by incomplete TCP sessions. SYN Cookies are preferred over Random Early Drop.

Audit:

From GUI:
Navigate to `Network` > `Network Profiles` > `Zone Protection` > `Zone Protection Profile` > `Flood Protection tab`
Verify the SYN box is `checked`

ARCHIVE

Verify the Action dropdown is `SYN Cookies`
Verify Alert is `20000` (or appropriate for org)
Verify Activate is `25000` (50% of maximum for firewall model)
Verify Maximum is `1000000` (or appropriate for org)

Remediation:

From GUI:
Navigate to `Network` > `Network Profiles` > `Zone Protection` > `Zone Protection Profile` > `Flood Protection tab`
Check the SYN box
Set the Action dropdown to `SYN Cookies`
Set Alert to `20000` (or appropriate for org)
Set Activate to `25000` (50% of maximum for firewall model)
Set Maximum to `1000000` (or appropriate for org)

Default Value:

Not Configured

References:

1. "Understanding DoS Protection" - https://live.paloaltonetworks.com/docs/DOC-5078
2. "Syn Cookie Operation" - https://live.paloaltonetworks.com/docs/DOC-1542
3. "How to Determine if Configured DoS Classify TCP SYN Cookie Alarm, Activate and Maximal Rate is Triggered" - https://live.paloaltonetworks.com/docs/DOC-6801
4. "Threat Prevention Deployment Tech Note" - https://live.paloaltonetworks.com/docs/DOC-3094
5. "What are the Differences between DoS Protection and Zone Protection?" - https://live.paloaltonetworks.com/docs/DOC-4501
6. "Application DDoS Mitigation" - https://live.paloaltonetworks.com/docs/DOC-7158

ARCHIVE

6.17 Ensure that a Zone Protection Profile with tuned Flood Protection settings enabled for all flood types is attached to all untrusted zones (Scored)

Profile Applicability:

- Level 2

Description:

Enable all Flood Protection options in the Zone Protection Profile attached to all untrusted zones. The Alert, Activate, and Maximum settings for Flood Protection depend highly on the environment and device used. Perform traffic analysis on the specific environment and firewall to determine accurate thresholds. Do not rely on default values to be appropriate for an environment.

Rationale:

Without flood protection, it may be possible for an attacker, through the use of a botnet or other means, to overwhelm network resources. Flood protection does not completely eliminate this risk; rather, it provides a layer of protection. Without a properly configured zone protection profile applied to untrusted interfaces, the protected / trusted networks are susceptible to large number of attacks. While many of these involve denial of service, some of these attacks are designed to evade IPS systems (fragmentation attacks for instance) or to evade basic firewall protections (source routing and record route attacks).

Audit:

In the GUI, navigate to Network > Network Profiles > Zone Protection > Flood Protection.

Ensure that all settings are enabled with at least the default values.

Navigate to `Network > Zones`, select each untrusted zone in turn, and ensure that the Zone Protection Profile is set.

or

Execute the following CLI command to verify that Zone Protection is configured:

```
username@hostname#run show zone-protection <zonename>
```

Remediation:

In the GUI

ARCHIVE

Navigate to `Network` > `Network Profiles` > `Zone Protection` > `Flood Protection`.

Set all settings to "enabled" with at least the default values.

Navigate to `Network > Zones`, select each untrusted zone in turn, and set the Zone Protection Profile.

or

Execute the following CLI command to configure Zone Protection:

```
username@hostname#set network profiles zone-protection-profile
```

Default Value:

Not Configured

References:

1. "Understanding DoS Protection" - https://live.paloaltonetworks.com/docs/DOC-5078
2. "Threat Prevention Deployment Tech Note" - https://live.paloaltonetworks.com/docs/DOC-3094
3. "What are the Differences between DoS Protection and Zone Protection?" - https://live.paloaltonetworks.com/docs/DOC-4501

ARCHIVE

6.18 Ensure that all zones have Zone Protection Profiles with all Reconnaissance Protection settings enabled, tuned, and set to appropriate actions (Scored)

Profile Applicability:

- Level 1

Description:

Enable all three scan options in a Zone Protection profile. Do not configure an action of Allow for any scan type. The exact interval and threshold values must be tuned to the specific environment. Less aggressive settings are typically appropriate for trusted zones, such as setting an action of alert for all scan types.

Attach appropriate Zone Protection profiles meeting these criteria to all zones. Separate Zone Protection profiles for trusted and untrusted zones is a best practice.

Rationale:

Port scans and host sweeps are common in the reconnaissance phase of an attack. Bots scouring the Internet in search of a vulnerable target may also scan for open ports and available hosts. Reconnaissance Protection will allow for these attacks to be either alerted on or blocked altogether.

Audit:

Navigate to `Network > Network Profiles > Zone Protection > Zone Protection Profile > Reconnaissance Protection`.

Verify that TCP Port Scan is enabled, its Action is set to 'block-ip', its Interval is set to '5', and its Threshold is set to '20'.

Verify that Host Sweep is enabled, its Action is set to 'block', its Interval is set to '10', and its Threshold is set to '30'.

Verify that UDP Port Scan is enabled, its Action is set to 'alert', its Interval is set to '10', and its Threshold is set to '20'.

Remediation:

Navigate to `Network > Network Profiles > Zone Protection > Zone Protection Profile > Reconnaissance Protection`.

ARCHIVE

Set TCP Port Scan to enabled, its Action to 'block-ip', its Interval to '5', and its Threshold to '20'.

Set Host Sweep to enabled, its Action to 'block', its Interval to '10', and its Threshold to '30'.

Set UDP Port Scan to enabled, its Action to 'alert', its Interval to '10', and its Threshold to '20'.

or

Execute the following CLI command for each of the three scan types:

```
username@hostname#set network profiles zone-protection-profile
```

Default Value:

Not Configured

References:

1. "Host Sweep Triggering Method in Zone Protection Profile" - https://live.paloaltonetworks.com/docs/DOC-8703
2. "Understanding DoS Protection" - https://live.paloaltonetworks.com/docs/DOC-5078
3. "Threat Prevention Deployment Tech Note" - https://live.paloaltonetworks.com/docs/DOC-3094
4. "What are the Differences between DoS Protection and Zone Protection?" - https://live.paloaltonetworks.com/docs/DOC-4501
5. "PAN-OS Administrator's Guide 6.1 (English)" - https://live.paloaltonetworks.com/docs/DOC-8246

ARCHIVE

6.19 Ensure all zones have Zone Protection Profiles that drop specially crafted packets (Scored)

Profile Applicability:

- Level 1

Description:

For all zones, attach a Zone Protection Profile that is configured to drop packets with a spoofed IP address or a mismatched overlapping TCP segment, and packets with malformed, strict source routing, or loose source routing IP options set.

Rationale:

Using specially crafted packets, an attacker may attempt to evade or diminish the effectiveness of network security devices. Enabling the options in this recommendation lowers the risk of these attacks.

Audit:

Navigate to `Network > Network Profiles > Zone Protection > Zone Protection Profile > Packet Based Attack Protection > TCP/IP Drop`.

Verify `Spoofed IP address` is checked.

Verify `Mismatched overlapping TCP segment` is checked.

Under `IP Option Drop`, verify that `Strict Source Routing`, `Loose Source Routing`, and `Malformed` are all checked. Additional options may also be checked.

Remediation:

Navigate to `Network > Network Profiles > Zone Protection > Zone Protection Profile > Packet Based Attack Protection > TCP/IP Drop`.

Set `Spoofed IP address` to be checked.

Set `Mismatched overlapping TCP segment` to be checked.

Under `IP Option Drop`, set `Strict Source Routing`, `Loose Source Routing`, and `Malformed` to all be checked. Additional options may also be set if desired.

ARCHIVE

Default Value:

Not Configured

References:

1. "Understanding DoS Protection" - https://live.paloaltonetworks.com/docs/DOC-5078
2. "Threat Prevention Deployment Tech Note" - https://live.paloaltonetworks.com/docs/DOC-3094
3. "What are the Differences between DoS Protection and Zone Protection?" - https://live.paloaltonetworks.com/docs/DOC-4501
4. "PAN-OS Administrator's Guide 6.1 (English)" - https://live.paloaltonetworks.com/docs/DOC-8246

ARCHIVE

7 Security Policies

The Security Policies section covers requirements for application and service security policies.

7.1 Ensure application security policies exist when allowing traffic from an untrusted zone to a more trusted zone (Scored)

Profile Applicability:

- Level 1

Description:

When permitting traffic from an untrusted zone, such as the Internet or guest network, to a more trusted zone, such as a DMZ segment, create security policies specifying which specific applications are allowed.

Enhanced Security Recommendation:
Require specific application policies when allowing any traffic, regardless of the trust level of a zone. This may require SSL interception, and may also not be possible in all environments.

Rationale:

To avoid unintentionally exposing systems and services, rules allowing traffic from untrusted zones to trusted zones should be as specific as possible. Application-based rules, as opposed to service/port rules, further tighten what traffic is allowed to pass.

Audit:

Navigate to `Policies > Security`.
Verify a Security Policy exists with:

Source:
`Zone` set to `OUTSIDE`
`Address` set to `any Destination`

Destination:
`Zone` set to `DMZ`
`Address` set to <DMZ IP Address>

ARCHIVE

`Application` set to `web-browsing`
`Service` set to `application-default`

Remediation:

Navigate to `Policies > Security`.
Set a Security Policy with:

Source:
`Zone` set to `OUTSIDE`
`Address` set to `any Destination`

Destination:
`Zone` set to `DMZ`
`Address` set to <DMZ IP Address>
`Application` set to `web-browsing`
`Service` set to `application-default`

Default Value:

Not Configured

References:

1. "PAN-OS Administrator's Guide 6.1 (English)" - https://live.paloaltonetworks.com/docs/DOC-8246

ARCHIVE

7.2 Ensure 'Service setting of ANY' in a security policy allowing traffic does not exist (Scored)

Profile Applicability:

- Level 1

Description:

Create security policies specifying application-default for the Service setting, or the specific ports desired. The Service setting of any should not be used for any policies that allow traffic.

Rationale:

App-ID requires a number of packets to traverse the firewall before an application can be identified and either allowed or dropped. Due to this behavior, even when an application is defined in a security policy, a service setting of `any` may allow a device in one zone to perform ports scans on IP addresses in a different zone. In addition, this recommendation helps to avoid an App-ID cache pollution attack.

Because of how App-ID works, configuring the service Setting to "Any" allows some initial traffic to reach the target host before App-ID can recognize and appropriately restrict the traffic. Setting the Service Setting to application specific at least restricts the traffic to the target applications or protocols for that initial volume of traffic.

Audit:

Navigate to `Policies > Security`.
Verify a Security Policy exists with:

Source:
`Zone` set to `OUTSIDE`
`Address` set to `any`

Destination:
`Zone` set to `DMZ`
`Address` set to `<DMZ IP Address>`
`Application` set to `web-browsing`
`Service` set to `application-default` and NOT to `any`

ARCHIVE

Remediation:

Navigate to `Policies > Security`.
Set a Security Policy that has:

Source:
Zone set to `OUTSIDE`
`Address` set to `any`

Destination:
`Zone` set to `DMZ`
`Address` set to `<DMZ IP Address>`
`Application` set to `web-browsing`
`Service` set to `application-default` and NOT to `any`

Default Value:

Not Configured

References:

1. "Security Policy Guidelines" - https://live.paloaltonetworks.com/docs/DOC-3469
2. "Security Bulletin: App-ID Cache Pollution" - http://researchcenter.paloaltonetworks.com/2012/12/app-id-cache-pollution-response/
3. "PAN-OS Administrator's Guide 6.1 (English)" - https://live.paloaltonetworks.com/docs/DOC-8246

ARCHIVE

7.3 Ensure 'Security Policy' denying any/all traffic exists at the bottom of the security policies ruleset (Scored)

Profile Applicability:

- Level 2

Description:

EXTREME CAUTION MUST BE USED BEFORE IMPLEMENTING THIS RECOMMENDATION, AS CERTAIN TRAFFIC PERMITTED BY DEFAULT WILL BE DENIED UNLESS SPECIFICALLY ALLOWED.

Create a security rule at the bottom of the security policies ruleset denying any traffic, regardless of source, destination, or application. Ensure this policy is set to log at session end, just before pre-defined intrazone-default and interzone-default rules.

Rationale:

In incident response, logging denied traffic is often just as important as logging permitted traffic. The logs for denied traffic can be used to establish a pattern of failed attack attempts before the final attack succeeds. This can be used in attribution and identification of the attacker, but can also be used to help identify which defenses need shoring up to defend against future attacks. Viewing denied traffic can also be useful for understanding how security policies are affecting traffic.

Palo Alto firewalls do not log denied traffic by default. Therefore, to acquire visibility to denied traffic, a "deny and log" policy must be created at the end of the security policy ruleset.

Audit:

Navigate to `Policies > Security`.
Verify a Security Policy exists with:

Name set to '`Deny and Log Any`'

Source:
`Zone` set to `Any`
`Address` set to `Any`

Destination:

ARCHIVE

`Zone` set to `Any`
`Address` set to `Any`
`Application` set to `Any`
`Service` set to `Any`
`Action` set to `Block`
`Profile` set to `None`

Remediation:

Navigate to `Policies > Security`.
Set a Security Policy with:

Name set to '`Deny and Log Any`'

Source:
`Zone` set to `Any`
`Address` set to `Any`

Destination:
`Zone` set to `Any`
`Address` set to `Any`
`Application` set to `Any`
`Service` set to `Any`
`Action` set to `Block`
`Profile` set to `None`

Default Value:

Not Configured

References:

1. "Dynamic Protocols on Palo Alto Networks Devices that Do Not Require Security Policies to Operate" - https://live.paloaltonetworks.com/docs/DOC-8114
2. "Security Policy Guidelines" - https://live.paloaltonetworks.com/docs/DOC-3469

ARCHIVE

8 Decryption

The Decryption section covers requirements for the SSL Forward Proxy policy and the SSL Inbound Inspection policy.

8.1 Ensure 'SSL Forward Proxy Policy' for traffic destined to the Internet is configured (Scored)

Profile Applicability:

- Level 1

Description:

Configure SSL Forward Proxy for all traffic destined to the Internet. Include all categories except financial-services and health-and-medicine.

Rationale:

Without SSL inspection, the firewall cannot apply many of its protection features against encrypted traffic. The amount of encrypted malware traffic continues to rise, and legitimate websites using SSL encryption are hacked or tricked into delivering malware on a frequent basis. As encryption on the Internet continues to grow at a rapid rate, SSL inspection is no longer optional as a practical security measure. If proper decryption is not configured, it follows that the majority of traffic is not being fully inspected for malicious content or policy violations. This is a major exposure, allowing delivery of exploits and payloads direct to user desktops.

Audit:

Navigate to `Policies > Decryption`.

Verify `SSL Forward Proxy` is set for all traffic destined to the Internet. Include all categories except financial-services and health-and-medicine.

Remediation:

Navigate to `Policies > Decryption`.

Set `SSL Forward Proxy` for all traffic destined to the Internet. Include all categories except financial-services and health-and-medicine.

ARCHIVE

Default Value:

Not Configured

References:

1. "How to Implement SSL Decryption" - https://live.paloaltonetworks.com/docs/DOC-1412
2. "PAN-OS Administrator's Guide 6.1 (English)" - https://live.paloaltonetworks.com/docs/DOC-8246

ARCHIVE

8.2 Ensure 'SSL Inbound Inspection' is required for all untrusted traffic destined for servers using SSL or TLS (Scored)

Profile Applicability:

- Level 1

Description:

Configure SSL Inbound Inspection for all untrusted traffic destined for servers using SSL or TLS.

Rationale:

Without SSL Inbound Inspection, the firewall is not able to protect SSL or TLS-enabled webservers against many threats.

Audit:

Navigate to `Policies > Decryption`.

Verify `SSL Inbound Inspection` is set appropriately for all untrusted traffic destined for servers using SSL or TLS.

Remediation:

Navigate to `Policies > Decryption`.

Set `SSL Inbound Inspection` appropriately for all untrusted traffic destined for servers using SSL or TLS.

Default Value:

Not Configured

ARCHIVE

8.3 Ensure that the Certificate used for Decryption is Trusted (Not Scored)

Profile Applicability:

- Level 1
- Level 2

Description:

The CA Certificate used for in-line HTTP Man in the Middle should be trusted by target users. There are two classes of users that need to be considered.

1: Users that are members of the organization, users of machines under control of the organization. For these people and machines, ensure that the CA Certificate is in one of the Trusted CA certificate stores. This is easily done in Active Directory, using Group Policies for instance. A MDM (Mobile Device Manager) can be used to accomplish the same task for mobile devices such as telephones or tablets. Other central management or orchestration tools can be used for Linux or "IoT" (Internet of Things) devices.

2: Users that are not member of the organization - often these are classed as "Visitors" in the policies of the organization. If a public CA Certificate is a possibility for your organization, then that is one approach. A second approach is to not decrypt affected traffic - this is easily done, but leaves the majority of "visitor" traffic uninspected and potentially carrying malicious content. The final approach, and the one most commonly seen, is to use the same certificate as is used for member's organization. In this last case, visitors will see a certificate warning, but the issuing CA will be the organization that they are visiting.

Rationale:

Using a self-signed certificate, or any certificate that generates a warning in the browser, means that members of the organization have no method of determining if they are being presented with a legitimate certificate, or an attacker's "man in the middle' certificate. It also very rapidly teaches members of the organization to bypass all security warnings of this type.

Audit:

Verify the CA Certificate(s):
Navigate to `Device` > `Setup` > `Certificate Management` > `Certificates`
Verify the Certificate Profile needed for the SSL Forward Proxy:

ARCHIVE

Navigate to `Device` > `Setup` > `Certificate Management` > `Certificate Profile`

Verify that the decryption profile includes the settings described in the SSL Forward Proxy guidance in this document:
Navigate to `Objects` > `Decryption Profile`

Verify that the Decryption Policy is applied to the appropriate interfaces and has the categories assigned to it that comply with your organization's internal policies, regulatory requirements and legal requirements.

Navigate to `Policies` > `Decryption`
Source: all internal user subnets
Destination: all target zones (typically this is the public internet)
Excluded URL categories: include Health Care, Personal Banking and any other category that exposes PII, PHI or that exposes any information that might be described in your organization's internal policies, regulatory framework, privacy requirements or legal requirements as protected.
Decryption Policy Rule: include the SSL Forward Proxy defined above, and the Decryption Profile defined above

Remediation:

Set the CA Certificate(s):
Navigate to `Device` > `Setup` > `Certificate Management` > `Certificates`
Set the Certificate Profile needed for the SSL Forward Proxy:
Navigate to `Device` > `Setup` > `Certificate Management` > `Certificate Profile`

Set the decryption profile to include the settings described in the SSL Forward Proxy guidance in this document:
Navigate to `Objects` > `Decryption Profile`

Set the Decryption Policy to be applied to the appropriate interfaces and to have the categories assigned to it that comply with your organization's internal policies, regulatory requirements and legal requirements.

Navigate to `Policies` > `Decryption`
Source: all internal user subnets
Destination: all target zones (typically this is the public internet)
Excluded URL categories: include Health Care, Personal Banking and any other category that exposes PII, PHI or that exposes any information that might be described in your organization's internal policies, regulatory framework, privacy requirements or legal requirements as protected.

ARCHIVE

Decryption Policy Rule: include the SSL Forward Proxy defined above, and the Decryption Profile defined above

Default Value:

Decryption is not enabled by default.

References:

1. https://live.paloaltonetworks.com/t5/Configuration-Articles/How-to-Implement-and-Test-SSL-Decryption/ta-p/59719
2. https://www.paloaltonetworks.com/documentation/61/pan-os/pan-os/certificate-management
3. https://live.paloaltonetworks.com/t5/Management-Articles/SSL-certificates-resource-list/ta-p/53068
4. http://palo-alto.wikia.com/wiki/Certificates

ARCHIVE

Appendix: Summary Table

Control		Set Correctly	
		Yes	No
1	**Device Setup**		
1.1	**General Settings**		
1.1.1	Ensure 'Login Banner' is set (Scored)	☐	☐
1.1.2	Ensure 'Enable Log on High DP Load' is enabled (Scored)	☐	☐
1.2	**Management Interface Settings**		
1.2.1	Ensure 'Permitted IP Addresses' is set to those necessary for device management (Scored)	☐	☐
1.2.2	Ensure 'Permitted IP Addresses' is set for all management profiles where SSH, HTTPS, or SNMP is enabled (Scored)	☐	☐
1.2.3	Ensure HTTP and Telnet options are disabled for the Management Interface (Scored)	☐	☐
1.2.4	Ensure valid certificate is set for browser-based administrator interface (Not Scored)	☐	☐
1.3	**Minimum Password Requirements**		
1.3.1	Ensure 'Minimum Password Complexity' is enabled (Scored)	☐	☐
1.3.2	Ensure 'Minimum Length' is greater than or equal to 12 (Scored)	☐	☐
1.3.3	Ensure 'Prevent Password Reuse Limit' is set to 24 or more passwords (Scored)	☐	☐
1.3.4	Ensure 'Required Password Change Period' is less than or equal to 90 days (Scored)	☐	☐
1.3.5	Ensure 'Password Profiles' do not exist (Scored)	☐	☐
1.3.6	Ensure 'Minimum Uppercase Letters' is greater than or equal to 1 (Scored)	☐	☐
1.3.7	Ensure 'Minimum Lowercase Letters' is greater than or equal to 1 (Scored)	☐	☐
1.3.8	Ensure 'Minimum Numeric Letters' is greater than or equal to 1 (Scored)	☐	☐
1.3.9	Ensure 'Minimum Special Characters' is greater than or equal to 1 (Scored)	☐	☐
1.3.10	Ensure 'Block Username Inclusion' is enabled (Scored)	☐	☐
1.3.11	Ensure 'New Password Differs By Characters' is greater than or equal to 3 (Scored)	☐	☐
1.4	**Authentication Settings (for Device Mgmt)**		
1.4.1	Ensure 'Idle timeout' is less than or equal to 10 minutes for device management (Scored)	☐	☐
1.4.2	Ensure 'Failed Attempts' and 'Lockout Time' for	☐	☐

ARCHIVE

	Authentication Profile are properly configured (Scored)		
1.5	**SNMP Polling Settings**		
1.5.1	Ensure 'V3' is selected for SNMP polling (Scored)	☐	☐
1.6	**Device Services Settings**		
1.6.1	Ensure 'Verify Update Server Identity' is enabled (Scored)	☐	☐
1.6.2	Ensure redundant NTP servers are configured appropriately (Scored)	☐	☐
1.6.3	Ensure that the certificate securing Remote Access VPNs is valid (Not Scored)	☐	☐
2	**User Identification**		
2.1	Ensure that IP addresses are mapped to usernames (Scored)	☐	☐
2.2	Ensure that WMI probing is disabled (Scored)	☐	☐
2.3	Ensure that User-ID is only enabled for internal trusted interfaces (Scored)	☐	☐
2.4	Ensure that 'Include/Exclude Networks' is used if User-ID is enabled (Scored)	☐	☐
2.5	Ensure that the User-ID Agent has minimal permissions if User-ID is enabled (Scored)	☐	☐
2.6	Ensure that the User-ID service account does not have interactive logon rights (Scored)	☐	☐
2.7	Ensure remote access capabilities for the User-ID service account are forbidden. (Not Scored)	☐	☐
2.8	Ensure that security policies restrict User-ID Agent traffic from crossing into untrusted zones (Scored)	☐	☐
3	**High Availability**		
3.1	Ensure a fully-synchronized High Availability peer is configured (Scored)	☐	☐
3.2	Ensure 'High Availability' requires Link Monitoring and/or Path Monitoring (Scored)	☐	☐
3.3	Ensure 'Passive Link State' and 'Preemptive' are configured appropriately (Scored)	☐	☐
4	**Dynamic Updates**		
4.1	Ensure 'Antivirus Update Schedule' is set to download and install updates hourly (Scored)	☐	☐
4.2	Ensure 'Applications and Threats Update Schedule' is set to download and install updates daily (Scored)	☐	☐
5	**Wildfire**		
5.1	Ensure that WildFire file size upload limits are maximized (Scored)	☐	☐
5.2	Ensure forwarding is enabled for all applications and file types in WildFire file blocking profiles (Scored)	☐	☐
5.3	Ensure a WildFire file blocking profile is enabled for all security policies allowing Internet traffic flows (Scored)	☐	☐

ARCHIVE

5.4	Ensure forwarding of decrypted content to WildFire is enabled (Scored)	☐	☐
5.5	Ensure all WildFire session information settings are enabled (Scored)	☐	☐
5.6	Ensure alerts are enabled for malicious files detected by WildFire (Scored)	☐	☐
5.7	Ensure 'WildFire Update Schedule' is set to download and install updates every 15 minutes (Scored)	☐	☐
6	**Security Profiles**		
6.1	Ensure at least one antivirus profile is set to block on all decoders except 'imap' and 'pop3' (Scored)	☐	☐
6.2	Ensure a secure antivirus profile is applied to all relevant security policies (Scored)	☐	☐
6.3	Ensure an anti-spyware profile is configured to block on all spyware severity levels, categories, and threats (Scored)	☐	☐
6.4	Ensure DNS sinkholing is configured on all anti-spyware profiles in use (Scored)	☐	☐
6.5	Ensure passive DNS monitoring is set to enabled on all anti-spyware profiles in use (Scored)	☐	☐
6.6	Ensure a secure anti-spyware profile is applied to all security policies permitting traffic to the Internet (Scored)	☐	☐
6.7	Ensure a Vulnerability Protection Profile is set to block attacks against critical and high vulnerabilities, and set to default on medium, low, and informational vulnerabilities (Scored)	☐	☐
6.8	Ensure a secure Vulnerability Protection Profile is applied to all security rules allowing traffic (Scored)	☐	☐
6.9	Ensure that PAN-DB URL Filtering is used (Scored)	☐	☐
6.10	Ensure that URL Filtering uses the action of “block” or “override” on the <enterprise approved value> URL categories (Scored)	☐	☐
6.11	Ensure that access to every URL is logged (Scored)	☐	☐
6.12	Ensure all HTTP Header Logging options are enabled (Scored)	☐	☐
6.13	Ensure secure URL filtering is enabled for all security policies allowing traffic to the Internet (Scored)	☐	☐
6.14	Ensure alerting after a threshold of credit card or Social Security numbers is detected is enabled (Scored)	☐	☐
6.15	Ensure a secure Data Filtering profile is applied to all security policies allowing traffic to or from the Internet (Scored)	☐	☐
6.16	Ensure that a Zone Protection Profile with an enabled SYN Flood Action of SYN Cookies is attached to all untrusted zones (Scored)	☐	☐
6.17	Ensure that a Zone Protection Profile with tuned Flood Protection settings enabled for all flood types is attached to	☐	☐

ARCHIVE

	all untrusted zones (Scored)		
6.18	Ensure that all zones have Zone Protection Profiles with all Reconnaissance Protection settings enabled, tuned, and set to appropriate actions (Scored)	☐	☐
6.19	Ensure all zones have Zone Protection Profiles that drop specially crafted packets (Scored)	☐	☐
7	**Security Policies**		
7.1	Ensure application security policies exist when allowing traffic from an untrusted zone to a more trusted zone (Scored)	☐	☐
7.2	Ensure 'Service setting of ANY' in a security policy allowing traffic does not exist (Scored)	☐	☐
7.3	Ensure 'Security Policy' denying any/all traffic exists at the bottom of the security policies ruleset (Scored)	☐	☐
8	**Decryption**		
8.1	Ensure 'SSL Forward Proxy Policy' for traffic destined to the Internet is configured (Scored)	☐	☐
8.2	Ensure 'SSL Inbound Inspection' is required for all untrusted traffic destined for servers using SSL or TLS (Scored)	☐	☐
8.3	Ensure that the Certificate used for Decryption is Trusted (Not Scored)	☐	☐

ARCHIVE

Appendix: Change History

Date	Version	Changes for this version
09-30-16	v1.0.0	Initial Release

ARCHIVE